RansomEye

AI-Driven Ransomware Detection, Containment, and Forensic Response

Draft - Technical Architecture Whitepaper

Version 1.0, March 2026

Lead Architect: Gagandeep Singh Maken
Gagan@RansomEye.Tech | www.RansomEye.Tech
Indian Patent Applications: 202521051303, 202521129733

CLASSIFICATION: CONFIDENTIAL, Internal Engineering

Table of Contents

1. Executive Summary....5
1.1 The Problem....5
1.2 Why Existing Systems Fail....5
1.3 What RansomEye Does Differently....5
1.4 Deployment Model....6
1.5 Risk Boundaries....6
2. Abstract....7
3. Intended Audience....8
4. Problem Definition....9
4.1 The Ransomware Threat Landscape....9
4.2 Structural Failures of Current Solutions....9
4.2.1 Cloud Dependency Fragility....9
4.2.2 Signature Evasion....9
4.2.3 Non-Deterministic and Unexplainable Decisions....9
4.2.4 Forensic Inadmissibility....9
4.3 India-Specific Regulatory Context....10
5. System Overview....11
5.1 Architecture Philosophy....11
5.2 Component Summary....11
5.3 Headline Metrics....11
6. Architecture....13
6.1 Component Topology....13
6.2 Kernel Telemetry Collection....14
6.2.1 Linux Agent, eBPF CO-RE....14
6.2.2 Windows Agent, ETW + WDK Minifilter....14
6.3 Network Detection (DPI Probe)....14
6.4 Core Engine....14
7. Trust Boundaries....15
7.1 Trust Zone Model....15
7.2 Three-Tier PKI Hierarchy....16
7.3 Network Isolation Layers....16
7.4 Certificate Expiry Monitoring....16
8. Signal Fusion....17
8.1 Signal Definitions....17
8.2 Honey Infrastructure and Deception Signal....18
8.3 Shannon Entropy, File Signal Basis....18
9. Bayesian Detection Engine....19
9.1 Overview....19
9.2 Sigmoid Likelihood Mapping....20
9.3 Log-Space Fusion with Correlation Correction....20
9.4 Posterior Computation....20
9.5 AEC Classification Thresholds....21
9.6 Leave-One-Out (LOO) Explainability....21
10. Mathematical Assumptions....22
11. Determinism Guarantees....23
11.1 Computational Reproducibility....23
11.2 Floating-Point Constraints....23
11.3 Model Immutability....23
11.4 Frozen Prior for Forensic Replay....23
11.5 Seed Control....23
12. AI / ML / LLM Separation....25

12.1 Three-Layer Architecture....25
12.2 Layer 1, Machine Learning Signal Models....26
12.3 Layer 2, Bayesian Fusion Engine....26
12.4 Layer 3, LLM / SINE Engine....26
13. SINE Engine....27
13.1 Purpose and Scope....27
13.2 Model Specification....27
13.3 TINAE Forensic Framework....27
14. Ransomware Attack Scenario....28
14.1 Scenario Overview....28
14.2 Stage-by-Stage Analysis....29
14.2.1 T+0h, Initial Access....29
14.2.2 T+2h, C2 Establishment....29
14.2.3 T+6h, Lateral Movement and Privilege Escalation....29
14.2.4 T+8h, Honey File Access (Critical Detection Point)....29
14.2.5 T+8.5h, Mass Encryption Begins (AEC-3 on Third Endpoint)....29
14.3 Detection Outcome....29
15. Air-Gap Architecture....30
15.1 Operating State Taxonomy....30
15.2 OfflineEngine, Local Bayesian Inference....30
15.3 SQLite WAL Evidence Buffer....30
15.4 Signed Air-Gap Update Bundles....30
16. Cryptographic Forensics....31
16.1 WORM Evidence Architecture....31
16.2 RFC 6962 Merkle Tree Construction....31
16.3 Evidence Retention Tiers....31
16.4 Legal Admissibility Properties....31
17. Adversarial Model....33
17.1 Threat Model Scope....33
17.1a Adversary Classification....33
17.2 Adversarial Attacks and Mitigations....33
17.2.1 Signal Washing....33
17.2.2 Honey File Avoidance....33
17.2.3 Prior Manipulation....34
17.2.4 eBPF/ETW Provider Evasion....34
17.2.5 Low-Entropy Encryption....34
18. Failure Modes....35
18.1 Design Philosophy....35
18.2 Component Failure Inventory....35
18.3 Graceful Degradation Ladder....36
19. Validation Methodology....37
19.1 Test Taxonomy....37
19.2 Six Mandatory Release-Blocking Gates....37
20. Detection Characteristics....38
20.1 Per-Threat Detection Coverage....38
20.2 Indicative Detection Characteristics....38
21. Performance....40
21.1 Endpoint Agent Resource Budget....40
21.2 SIMD Acceleration....40
22. Deployment Model....42
22.1 Deployment Configurations....42
22.2 Deterministic Startup Sequence....42
23. Data Governance....43
23.1 Multi-Tenant Isolation....43

23.2 Data Minimisation.....43
23.3 Retention Policies.....43
24. Supply Chain Security.....44
24.1 License Policy.....44
24.2 Model Weight Governance.....44
24.3 Model Promotion and Shadow Deployment.....44
24.4 Binary Integrity.....44
25. Regulatory Alignment.....45
25.1 India Regulatory Framework.....45
25.1.1 CERT-In Cybersecurity Directions 2022.....45
25.1.2 Digital Personal Data Protection Act 2023.....45
25.1.3 RBI Cybersecurity Framework.....45
25.2 International Standards.....45
26. Differentiation.....46
26.1 Competitive Comparison.....46
27. Economic Considerations.....47
27.1 Total Cost of Ownership Model.....47
27.2 Regulatory Compliance Cost Avoidance.....47
27.3 Forensic Cost Avoidance.....47
27a. Trust Boundary Matrix.....48
28. Limitations.....50
28.1 V0.0 Feature Scope.....50
28.2 Detection Boundary Conditions.....50
28.3 Probabilistic Detection Caveat.....50
29. Conclusion.....51
Appendices.....52
A Appendix A, Bayesian Posterior Derivation and Kolmogorov Proof.....52
B Appendix B, IEEE 754 Parity Bound Derivation.....52
C Appendix C, Prometheus Metrics Reference.....52
D Appendix D, Red Team Exercise Summary.....53
E Appendix E, Supply Chain Control Summary.....53
F Appendix F, Key Management Reference.....54

1. Executive Summary

> Audience: Board, C-Suite, CISOs, Government Procurement Officers, no technical background required for this section.

1.1 The Problem

Ransomware is now the defining cyber threat facing governments, critical infrastructure, and enterprises. Attackers encrypt operational systems, exfiltrate sensitive data, and demand ransom, causing financial losses measured in the billions annually and, in critical-sector incidents, direct harm to public safety.

Traditional security products share a fundamental structural weakness: they depend on connectivity to vendor cloud systems to function. When the network is compromised, or when a deployment operates in a classified or sensitive environment that prohibits external connectivity, these products either fail silently or cease to operate entirely.

A second failure mode is equally important: most current systems cannot produce evidence that satisfies the standards of legal proceedings, regulatory audits, or government investigations. Logs can be deleted. Detection decisions are opaque. Forensic chains of custody are fragile or non-existent.

1.2 Why Existing Systems Fail

- Cloud-dependent detection: Signature and AI model updates require constant internet connectivity. Air-gapped or classified deployments cannot use these products.
- Signature-based lag: Ransomware families rotate encryption routines and obfuscation techniques faster than signatures can be updated.
- Opaque decisions: Most ML-based products cannot explain, in terms a court or regulator can evaluate, why a particular decision was made.
- Inadmissible evidence: Detection logs lack cryptographic integrity guarantees. Evidence can be disputed, deleted, or forged.
- Endpoint resource cost: Leading cloud-agent products consume 3–8% CPU and 200–500 MB RAM per endpoint, impacting operational performance.

1.3 What RansomEye Does Differently

RansomEye is designed from first principles to operate with complete autonomy, no internet, no vendor cloud, no signature updates required. It embeds a formally specified, probabilistically grounded detection engine directly on the customer's infrastructure, alongside a tamper-evident forensic evidence store that is designed to satisfy court standards.

The key differentiators are:

- Air-gap native: RansomEye is designed for completely isolated environments. All detection, investigation, and response capabilities operate with zero external connectivity, indefinitely.
- Behavioural physics: Detection is based on the mathematical physics of malware behaviour, entropy signatures, process genealogy, network periodicity, and cryptographic fingerprints, not on threat signatures that can be evaded.
- Legally defensible evidence: Every detection is cryptographically signed, encrypted, and anchored in a tamper-evident Merkle ledger. Evidence is designed to meet the Federal Rules of Evidence 803(6) business records exception.
- Proportionate resource usage: The endpoint agent is designed to consume no more than approximately 5% CPU and 256 MB RAM, verified under sustained telemetry load.

- Long-term autonomous evolution capability: The detection engine monitors its own statistical drift and recalibrates over time. The architecture is designed to support extended operation without mandatory external signature updates, subject to deployment-specific calibration and periodic governance review.

1.4 Deployment Model

RansomEye is deployed entirely on customer-owned infrastructure. There is no SaaS component, no vendor cloud dependency, and no telemetry transmitted outside the customer's network boundary. The system is suitable for classified environments, government networks, regulated industries, and any organisation with strict data sovereignty requirements.

The Core Server runs on a single VM or physical server. Lightweight agents are deployed on each monitored endpoint. A dedicated network probe captures traffic at the network perimeter. The Security Operations Centre (SOC) dashboard is accessed through a standard browser on the customer's internal network.

1.5 Risk Boundaries

RansomEye is designed to provide high-confidence detection of behavioural indicators consistent with ransomware and related attacks. Users should be aware of the following boundaries:

- Detection performance is bounded by the quality and coverage of endpoint telemetry. Endpoints that are offline or that block kernel-level monitoring cannot be observed.
- The detection model is probabilistic in its output (it produces a confidence P(H|E)), while the inference algorithm itself is deterministic. For identical inputs, the system produces identical outputs within a bounded floating-point tolerance. The system classifies threats on a confidence scale; it does not guarantee that every attack will be detected or that every alert will be a true positive.
- The product is in version V0.0. Several features, including full UI authentication, High Availability clustering, and TPM attestation verification, are staged for upcoming releases.
- Physical security of the Core Server is outside the system's scope. A physically compromised server may affect evidence integrity.

This whitepaper provides the full technical specification for independent evaluation by security professionals, regulators, and academic reviewers.

2. Abstract

RansomEye is a customer-hosted, air-gap-capable cybersecurity platform designed to detect, contain, and produce court-admissible forensic evidence for ransomware and advanced persistent threat (APT) activity. The platform combines kernel-level behavioural telemetry collection via eBPF (Linux) and Event Tracing for Windows (ETW), a five-signal Bayesian probabilistic detection engine, deception-based early-warning infrastructure, and a cryptographically sealed Write-Once-Read-Many (WORM) forensic evidence store anchored to an RFC 6962 Merkle ledger.

Detection inference is performed using a closed-form Bayesian posterior computation with Kish (1965) correlation correction (dampening factor $\lambda = 0.85$), producing a calibrated probability estimate $P(H|E) \in (0, 1)$ for each telemetry event. This computation is reproducible: for identical inputs, signal vector, prior, dampening factor, and likelihood parameters, posterior outputs are consistent across Python, Rust, and C++ implementations to within an absolute tolerance of 10^{-12}, subject to IEEE 754 double-precision arithmetic constraints. This reproducibility property supports forensic replay from stored intermediate values.

The architecture enforces strict separation between Machine Learning signal models, the deterministic Bayesian fusion engine, and the optional Large Language Model (LLM) narrative layer. The LLM has zero authority over detection outcomes. All inference executes locally on customer hardware using CPU-native computation; no GPU dependency exists in production. The architecture is designed to support extended autonomous operation without mandatory external threat intelligence feeds, through autonomous statistical drift detection and model recalibration. The effective operational duration depends on deployment-specific conditions, governance procedures, and threat landscape evolution.

Regulatory alignment is addressed for CERT-In 2022 (6-hour reporting), India DPDP Act 2023, RBI Cybersecurity Framework, ISO/IEC 27037:2012, NIST SP 800-86, and the Federal Rules of Evidence 803(6) business records exception. The product is covered by Indian Patent Applications 202521051303 and 202521129733.

3. Intended Audience

This document is intended for the following readership:

- Chief Information Security Officers (CISOs) and Chief Information Officers (CIOs) evaluating enterprise or government-grade security platforms.
- Security architects and engineers conducting technical due diligence.
- Government procurement officers and security clearance reviewers.
- Regulatory compliance officers evaluating alignment with applicable standards.
- Academic researchers in applied cryptography, probabilistic detection systems, and digital forensics.
- Legal counsel and forensic examiners assessing evidence admissibility.

Readers of the Executive Summary (Section 1) require no technical background. Sections 6 onward assume familiarity with probability theory, cryptography fundamentals, and operating system security concepts. Mathematical sections (8–11) assume undergraduate-level statistics.

4. Problem Definition

4.1 The Ransomware Threat Landscape

Ransomware attacks have evolved from opportunistic criminal operations to state-sponsored campaigns targeting critical infrastructure. The Verizon Data Breach Investigations Report 2023 documents ransomware involvement in approximately 24% of all breach incidents. Recovery costs frequently exceed USD 1 million per incident, excluding regulatory penalties and reputational damage.

Modern ransomware families implement a two-phase strategy: (1) credential theft, lateral movement, and data exfiltration during a dwell period averaging 21 days; followed by (2) mass encryption of operational data. Detection during the first phase, before encryption begins, is the primary engineering objective of RansomEye.

4.2 Structural Failures of Current Solutions

4.2.1 Cloud Dependency Fragility

The dominant architectural pattern in commercial endpoint detection and response (EDR) products requires continuous connectivity to vendor cloud infrastructure for signature updates, ML inference, and telemetry analysis. This creates a class of deployment environments where these products are architecturally unusable:

- Air-gapped government and military networks.
- Industrial Control Systems (ICS) and Operational Technology (OT) environments with strict network segmentation.
- Healthcare and financial environments with data sovereignty requirements prohibiting cross-border telemetry transmission.
- Disaster recovery scenarios where internet connectivity has been severed by the attacker.

4.2.2 Signature Evasion

Signature-based detection operates on the assumption that malware families are sufficiently invariant that their static characteristics can be enumerated in a lookup database. This assumption has been empirically falsified: modern ransomware kits compile with polymorphic obfuscators, use legitimate system tools (Living-off-the-Land), and rotate cryptographic keys per campaign. The effective detection window for a new signature is measured in hours to days.

4.2.3 Non-Deterministic and Unexplainable Decisions

Neural network-based anomaly detectors used in modern EDR products are non-deterministic due to floating-point non-associativity, GPU parallelism, and stochastic training. They cannot guarantee that a replayed sequence of events will produce the same classification decision. This property makes forensic replay, the reproduction of a detection decision from preserved evidence, a requirement under ISO/IEC 27037:2012, architecturally impossible.

4.2.4 Forensic Inadmissibility

Event logs produced by current security products lack sufficient cryptographic guarantees to survive adversarial challenge in legal proceedings. The absence of:

- Per-event cryptographic signatures binding each evidence record to a timestamp and system identity,
- An immutable, tamper-evident evidence chain (Merkle ledger),
- A deterministic, reproducible decision algorithm with frozen parameter sets,

...means that opposing counsel can reasonably challenge whether logged events occurred, whether they were recorded accurately, and whether the detection algorithm behaved consistently.

4.3 India-Specific Regulatory Context

The CERT-In Cybersecurity Directions 2022 mandate incident reporting within 6 hours of discovery, require 180-day log retention on Indian infrastructure, and impose data localisation obligations that prohibit transmission of security telemetry to foreign cloud infrastructure. The Digital Personal Data Protection Act 2023 further restricts cross-border transfer of data generated on Indian systems.

These requirements create a direct legal obligation for India-domiciled organisations to deploy security products that operate entirely within Indian data boundaries. Cloud-based EDR products structurally cannot satisfy this obligation without significant architectural modification.

5. System Overview

5.1 Architecture Philosophy

RansomEye is designed on three foundational engineering principles:

1. Fail-closed, not fail-open: any cryptographic, configuration, or infrastructure failure causes the affected component to terminate with a fatal error rather than degrade silently. No partial-operation degraded mode exists for security-critical infrastructure.
2. Air-gap as the design baseline: the system is designed for complete network isolation as its primary operating mode. Internet connectivity, when available, provides no additional detection capability; it is simply unused.
3. CPU-first computation: all ML inference, Bayesian computation, and LLM inference execute on CPU. GPU acceleration is used opportunistically if detected, but the system is fully functional without any GPU hardware.

5.2 Component Summary

The platform comprises the following components:

Component	Language / Runtime	Deployment	Key Function
Linux Agent	Rust 1.78 + eBPF CO-RE	Monitored endpoint	Kernel telemetry via kprobes/XDP, signal extraction, OfflineEngine
Windows Agent	C++17 + WDK + ETW	Monitored endpoint	ETW 14 providers, minifilter IRP, WFP enforcement, ELAM trust chain
DPI Network Probe	Rust 1.78 + nDPI 4.x	SPAN/tap port	L2–L7 protocol analysis, JA3 fingerprinting, beaconing, DGA detection
Core Engine	Go 1.24	Core server	gRPC/mTLS gateway, WORM manager, Merkle ledger, action dispatcher
AI Detection Service	Python 3.11	Core server (loopback)	5-signal Bayesian fusion, LOO explainability, drift detection
SINE Engine	Rust 1.78 + llama.cpp	Core server (loopback)	LLM forensic narrative generation, TINAE Q1–Q10 framework
SOC Dashboard	React 18 + TypeScript 5	nginx, port 443	35 dashboards, 170+ panels, WebSocket real-time alerts

Table 1: RansomEye component inventory.

5.3 Headline Metrics

The following design targets have been established for the V0.0 release. Actual performance is environment-dependent; these figures represent design intent and have been tested on reference hardware.

Metric	Design Target	Context
Agent CPU usage	**≤ 5% (hard cap, cgroup v2)**	At up to 1,000 events/s sustained; kernel hard throttle via cgroup v2

		cpu.max
Agent RAM usage	**≤ 256 MB (cgroup ceiling)**	Steady-state RSS approximately 30–60 MB on reference hardware; 256 MB is the enforced ceiling
Bayesian P99 latency	**< 5 ms**	Single-event posterior computation on CPU with AVX2 SIMD acceleration
Cross-implementation parity	**$\lvert\Delta P\rvert < 10^{-12}$**	Python AI Service vs Rust OfflineEngine; IEEE 754 error bounded at 1.3×10^{-15}
Maximum validated agent fleet	**5,000 agents**	On 32-core / 128 GB Core Server with pgBouncer connection pool
WORM evidence retention	**Up to 7 years (cold tier)**	Hot 0–90 days, Warm 91–730 days, Cold 731–2,555 days; filesystem 0444 immutable
Bayesian parity tolerance	**10^{-12}**	Verified across Python, Rust, and C++ implementations using 100 cross-implementation test vectors
Autonomous operation horizon	**Multi-year autonomous operation (deployment-dependent; subject to drift monitoring and governance recalibration)**	Without external signature updates, via concept drift detection and model recalibration

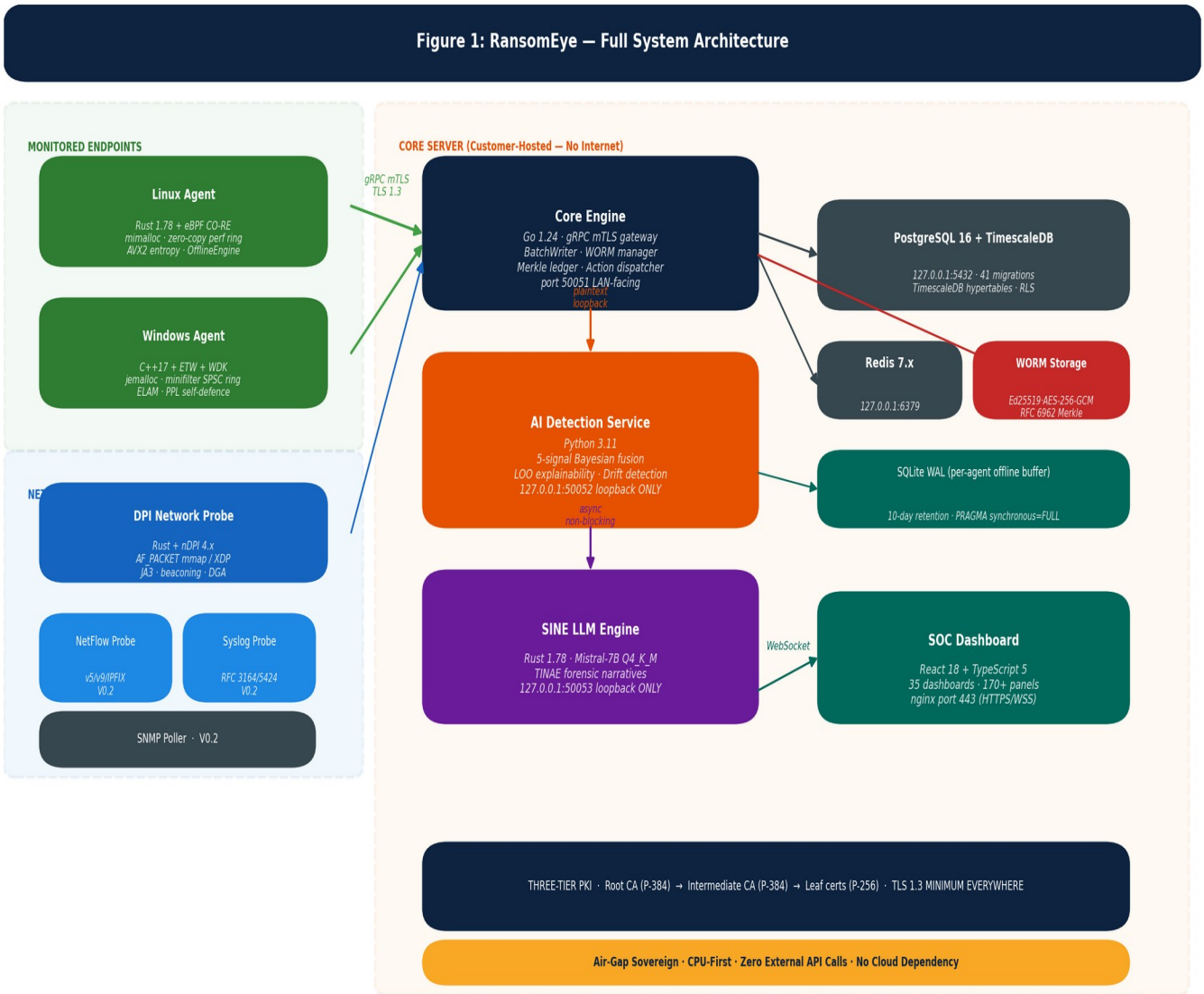
Table 2: RansomEye V0.0 headline performance targets.

6. Architecture

6.1 Component Topology

The full system architecture is shown in Figure 1 below. The design enforces a strict hierarchy: monitored endpoints and network sensors communicate exclusively with the Core Engine via mutually authenticated TLS 1.3 connections. The Core Engine is the only component that holds database credentials, filesystem write permissions to the WORM store, and a direct connection to the AI Detection Service. All internal microservices (AI Service, SINE Engine, PostgreSQL, Redis) bind exclusively to the IPv4 loopback address (127.0.0.1); IPv6 loopback binding is permanently prohibited across the entire platform.

Figure 1: RansomEye Full System Architecture



Full system architecture showing endpoint agents, network sensors, Core Engine, AI/LLM services, and data stores. All internal services bind to 127.0.0.1 only. External connectivity is never required.

6.2 Kernel Telemetry Collection

6.2.1 Linux Agent, eBPF CO-RE

The Linux Agent uses the Aya framework to load eBPF programs compiled with CO-RE (Compile Once, Run Everywhere) and BTF (BPF Type Format), enabling a single binary to execute on any Linux kernel version 5.4 or later. Telemetry is collected via kprobe hooks on execve(2), openat(2), write(2), read(2), setuid(2), and setcap(2), alongside XDP programs on the primary network interface.

The kernel-to-userspace event transport uses eBPF PerfEventArray with mmap(2)-based zero-copy ring buffers. No read(2) or recvfrom(2) syscall is issued per event; userspace reads directly from the same physical memory pages that the kernel writes. This eliminates all kernel-to-userspace copy overhead.

6.2.2 Windows Agent, ETW + WDK Minifilter

The Windows Agent subscribes to 14 ETW (Event Tracing for Windows) providers including Kernel-Process, Kernel-File, Security-Auditing, Threat-Intelligence, DNS-Client, PowerShell, WMI-Activity, and SMBServer. A WDK minifilter driver intercepts IRP_MJ_CREATE and IRP_MJ_WRITE operations at kernel altitude 328000, and a WFP (Windows Filtering Platform) callout provides network-layer enforcement capability.

The kernel driver and userspace service communicate via a zero-copy shared memory section (ZwCreateSection/MmMapLockedPagesSpecifyCache) with a lock-free SPSC ring buffer. This eliminates the approximately 2,000 ns per-event latency of traditional DeviceIoControl METHOD_BUFFERED I/O.

6.3 Network Detection (DPI Probe)

The DPI Network Probe is deployed at a SPAN or tap port, capturing traffic in promiscuous mode via AF_PACKET TPACKET_V3 mmap ring buffers (zero-copy). nDPI 4.x provides L2–L7 protocol classification, dynamically linked under LGPL-3.0. Detection algorithms include a coefficient-of-variation (CV) beaconing detector, a 5-indicator DNS tunneling scorer, a JA3/JA3S TLS fingerprinting engine, a DGA domain entropy classifier, and an OT/ICS protocol decoder for Modbus TCP and DNP3.

6.4 Core Engine

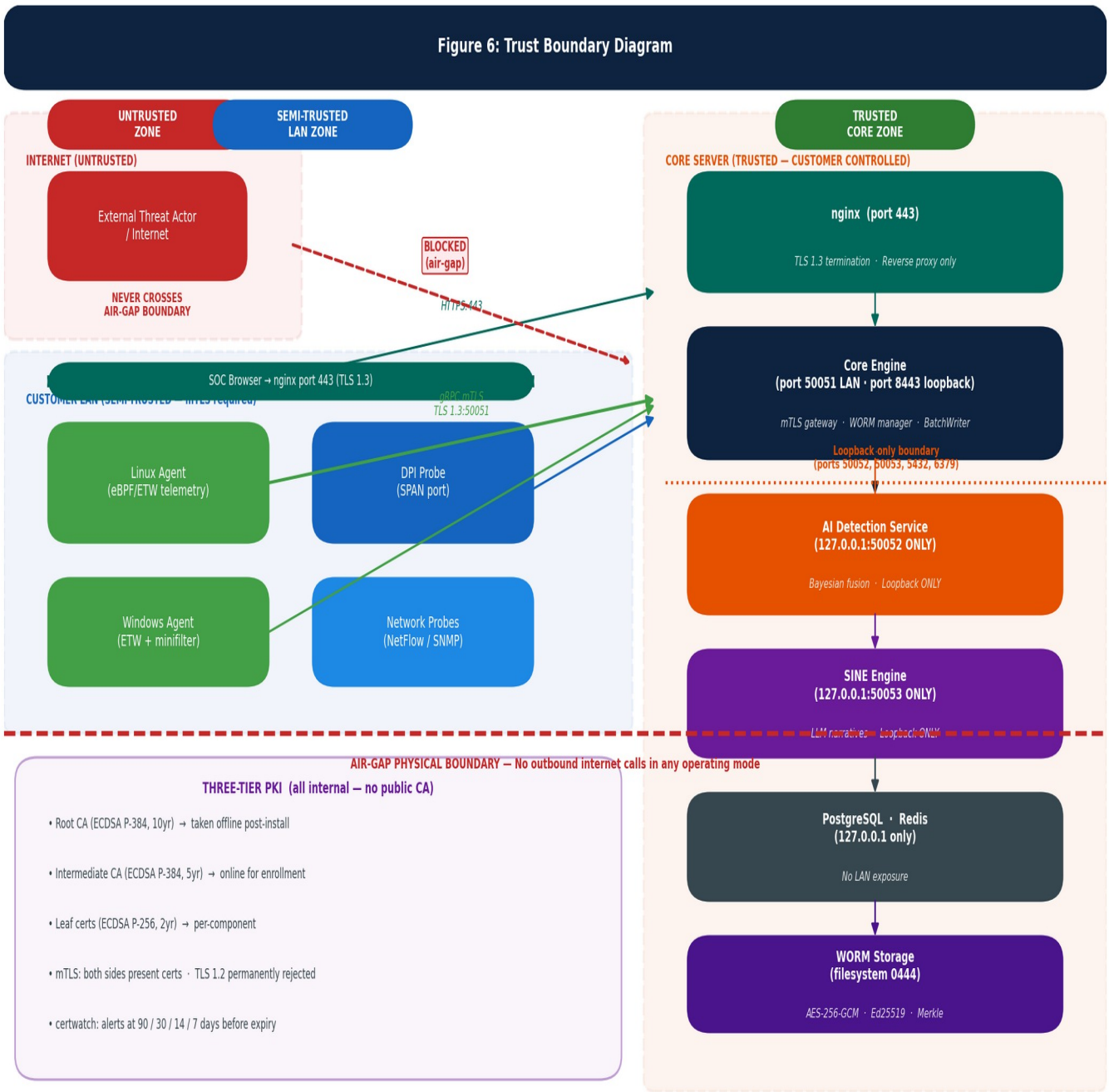
The Core Engine (Go 1.24) is the central coordination node. It owns all PostgreSQL queries through a pgBouncer connection pool, all WORM evidence sealing, the RFC 6962 Merkle ledger, and action dispatch to agents. The non-blocking event queue (capacity 1,024 events, CAS-based enqueue) ensures that a backlogged AI Service can never stall the gRPC ingestion path; agents receive a retriable RESOURCE_EXHAUSTED response and buffer events locally in SQLite WAL.

7. Trust Boundaries

7.1 Trust Zone Model

RansomEye enforces four distinct trust zones, as illustrated in Figure 6. Each zone boundary is enforced by cryptographic authentication and firewall rules installed by the deployment installer; no boundary can be crossed without a verified certificate chain.

Figure 6: Trust Boundary Diagram, Zone Separation and Authentication Enforcements



Trust zone diagram showing Untrusted (Internet), Semi-Trusted (Customer LAN), and Trusted (Core Server) zones separated by the air-gap boundary. All zone transitions require TLS 1.3 mTLS with three-tier PKI validation.

7.2 Three-Tier PKI Hierarchy

The PKI hierarchy is entirely internal to the customer deployment. No public CA or third-party certificate authority is involved in any mTLS trust chain. The hierarchy is:

4. Root CA (ECDSA P-384, 10-year validity, pathlen:1), self-signed, generated by the installer. The Root CA private key is taken offline immediately after signing the Intermediate CA and is never used again during normal operation.
5. Intermediate CA (ECDSA P-384, 5-year validity, pathlen:0), signed by the Root CA. Remains online to issue and renew leaf certificates. Protected by filesystem permissions (0400).
6. Leaf certificates (ECDSA P-256, 2-year validity), one per component instance. Used for mTLS client authentication and TLS server authentication.

TLS 1.2 is permanently prohibited across the entire platform. All connections use TLS 1.3 as the enforced minimum version. Expired certificates cause immediate connection rejection with no fallback.

7.3 Network Isolation Layers

Ports 50052 (AI Service), 50053 (SINE Engine), 5432 (PostgreSQL), 5433 (pgBouncer backend), and 6379 (Redis) are bound exclusively to 127.0.0.1 and protected by three independent enforcement layers:

7. Service configuration: each service's listen address is set to 127.0.0.1 explicitly in its configuration.
8. Firewall rules: the installer writes iptables/ufw rules rejecting all non-loopback traffic to these ports.
9. Startup validation: the Core Engine verifies that POSTGRES_HOST resolves to a loopback address and performs a fatal exit if any internal service is accessible from outside the loopback interface.

7.4 Certificate Expiry Monitoring

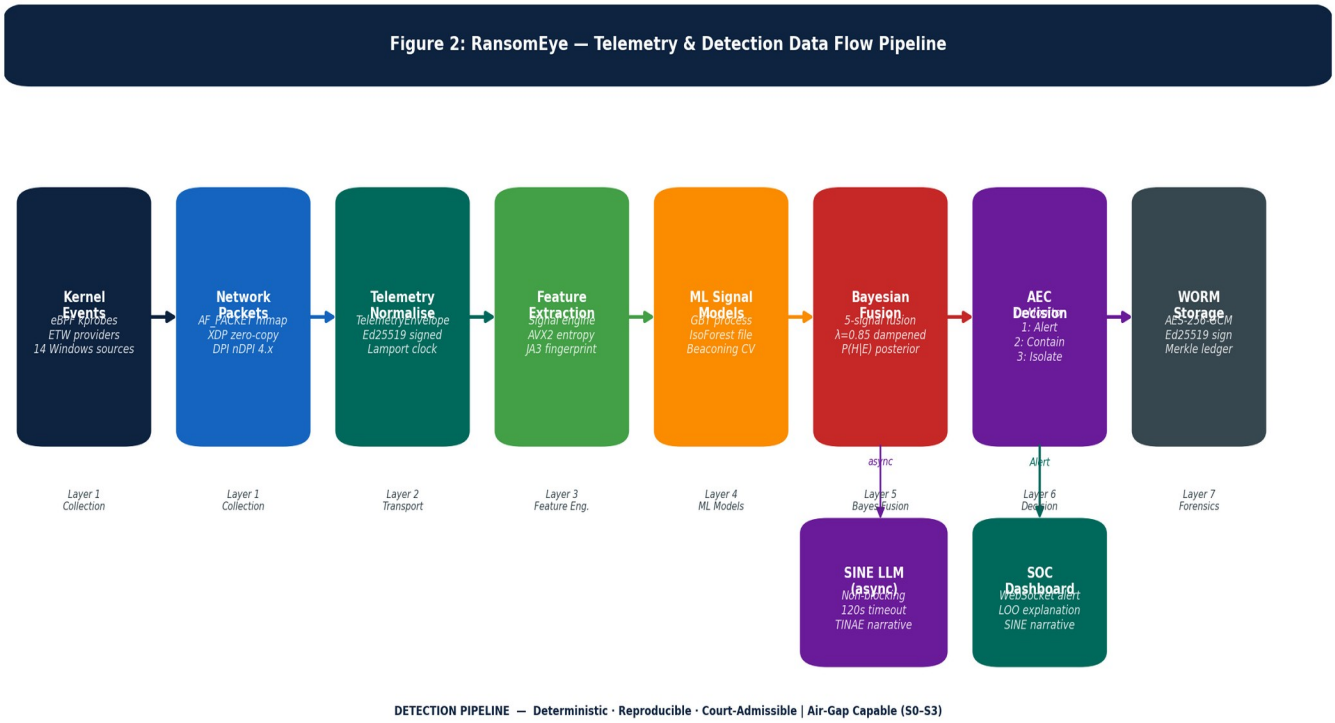
The certwatch goroutine within the Core Engine performs a daily scan of all agent and server certificates, emitting SOC alerts at 90-day, 30-day, 14-day, and 7-day thresholds before expiry. A systemd timer triggers monthly auto-renewal of the nginx TLS certificate in Mode 1 (internal CA) deployments.

8. Signal Fusion

8.1 Signal Definitions

The detection engine fuses five independent signal dimensions into a single posterior probability. Each signal is a normalised real value representing the degree of anomaly observed in a distinct behavioural channel. As shown in Figure 2, signals are computed from raw kernel telemetry before being passed to the Bayesian engine.

Figure 2: RansomEye Telemetry and Detection Data Flow Pipeline



Eight-stage detection pipeline from raw kernel events through feature extraction, ML signal models, Bayesian fusion, AEC decision, and WORM storage. The deception event path (s_d) is causally independent of the network-correlated signal chain.

Signal	Symbol	Domain	Source	Extraction	Default
Process	s_p	[0, 1]	eBPF kprobe / ETW	syscall burst ratio, privilege escalation, LOLbin patterns	0.5 (neutral)
File	s_f	[0, 1]	eBPF file probes / minifilter IRP	Shannon entropy of write samples (AVX2 SIMD), write frequency, extension churn	0.5 (neutral)
Network	s_n	[0, 1]	eBPF XDP / DPI probe	Connection frequency, CV beaconing, JA3 C2 fingerprint, DNS volume anomaly	0.5 (neutral)
User	s_u	[0, 1]	ETW Security-Auditing	Privilege events 4672/4688, Kerberoasting 4769 RC4, DCSync 4662, COM hijack	0.5 (neutral)
Deception	s_d	{0, 1}	HoneyTokenMana	Binary: 1.0 on any honey	0.0 (absent)

			ger ONLY	file/socket/UNC access; 0.0 otherwise	

Table 3: Signal dimension definitions. SIGNAL_UNAVAILABLE = −1.0 (ETW/eBPF provider failure); excluded from fusion rather than set to 0.0 to prevent false negative evidence injection.

8.2 Honey Infrastructure and Deception Signal

The deception signal s_d occupies a unique position in the fusion architecture. Four deployment invariants justify its Bayes Factor ceiling of 10,000:

10. No legitimate application may access the honey file paths (verified at deployment by scanning all scheduled tasks, backup agents, and application manifests).
11. Honey paths are absent from all configuration files, crontab entries, and backup agent configurations.
12. Honey directories are protected against accidental enumeration (0700 permissions on Linux, HIDDEN+SYSTEM ACL on Windows).
13. No network scanner or backup agent is configured to probe honey socket ports.

Under these invariants, the false-positive probability satisfies $p_{fp} \leq 10^{-4}$. With P(access | attacker present) ≥ 0.99, the Bayes Factor is $BF = 0.99 / 10^{-4} \approx 9{,}900 \approx 10{,}000$ (rounded conservatively). This exceeds Jeffreys' (1961) "decisive evidence" threshold (BF > 100) by two orders of magnitude.

8.3 Shannon Entropy, File Signal Basis

The file signal uses Shannon byte entropy as its primary feature. For a file write sample W of n bytes:

$$H(W) = -\Sigma_i\, p_i \cdot \log_2(p_i), \quad p_i = \text{count(byte } i) / n, \quad i \in \{0, \ldots, 255\}$$

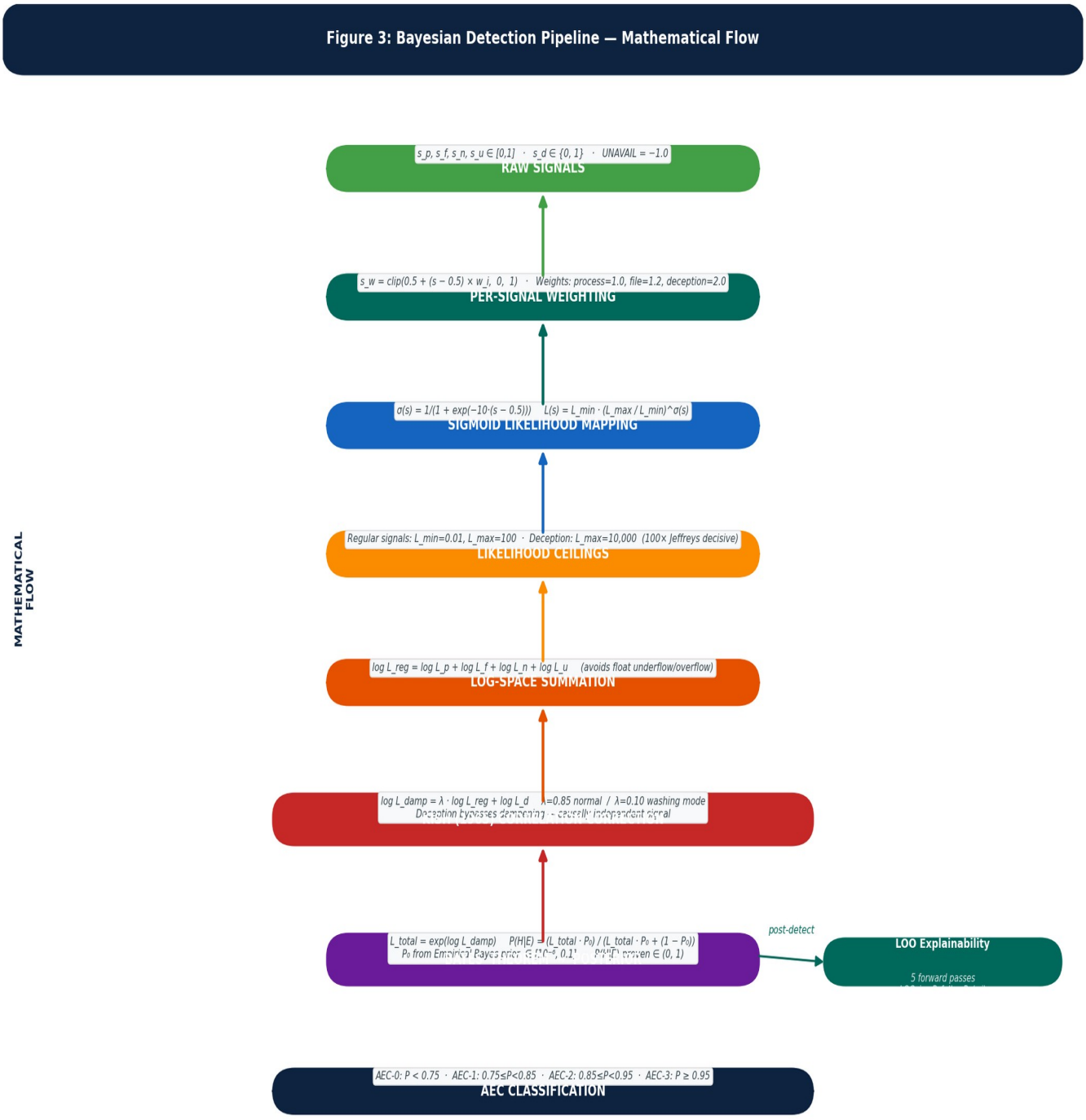
AES-256-GCM ciphertext produces H ≈ 7.95–8.00 bits/byte (theoretical maximum 8.0 bits/byte). Plaintext English prose produces H ≈ 3.5–4.5 bits/byte. The normalised entropy score s_f_entropy = H / 8.0 ∈ [0, 1] is computed over the first 64 bytes of each IRP_MJ_WRITE sample. The AVX2 SIMD path processes 32 bytes per lane, achieving approximately 32× speedup over scalar computation.

9. Bayesian Detection Engine

9.1 Overview

The Bayesian Detection Engine is the mathematical core of RansomEye. As illustrated in Figure 3, it receives the five-dimensional signal vector, applies sigmoid likelihood mapping, performs log-space fusion with Kish correlation correction, and computes the posterior probability P(H|E) using Bayes' theorem. Every step is closed-form; there are no stochastic elements.

Figure 3: Bayesian Detection Pipeline, Complete Mathematical Flow



Mathematical flow of the Bayesian detection pipeline from raw signals through likelihood mapping, correlation-corrected log-space fusion, posterior computation, AEC classification, and LOO explainability. All steps are deterministic closed-form operations.

9.2 Sigmoid Likelihood Mapping

Each signal value $s \in [0, 1]$ is mapped to a likelihood ratio $L(s)$ via a logistic sigmoid function. The mapping ensures that a neutral signal ($s = 0.5$) contributes exactly $L(0.5) = 1.0$ (multiplicative identity), leaving the posterior unchanged. The steepness parameter $k = 10$ and midpoint $x_0 = 0.5$ are fixed constants loaded from the model configuration file.

```
σ(s) = 1 / (1 + exp(−10 · (s − 0.5)))
L(s) = L_min · (L_max / L_min)^σ(s)
```

Likelihood ceiling parameters by signal dimension:

Signal	L_min	L_max	Ceiling Basis
Process, File, Network, User	0.01	100	Jeffreys (1961) "decisive evidence" scale: BF > 100 constitutes decisive evidence for H
Deception	0.01	**10,000**	First-principles derivation: BF = P(access|H) / P(access|¬H) ≥ 0.99 / 10^{-4} = 9,900 ≈ 10,000

Table 4: Likelihood ceiling parameters. The deception signal ceiling is 100× higher than regular signals, reflecting the extraordinary informativeness of a honey access event.

9.3 Log-Space Fusion with Correlation Correction

Direct multiplication of individual likelihood ratios would overcount evidence due to positive inter-signal correlation (empirically $\bar{\rho} \in [0.40, 0.70]$ during ransomware events). The Kish (1965) effective sample size framework provides the theoretical basis for the dampening correction.

For $k = 4$ regular signals with average inter-channel correlation $\bar{\rho} = 0.55$:

```
k_eff = k / (1 + (k − 1) · ρ̄) = 4 / (1 + 3 × 0.55) = 4 / 2.65 ≈ 1.509
```

The dampening factor $\lambda = 0.85$ is selected as a sensitivity-preserving calibration parameter rather than a strict derivation from the Kish effective sample size estimate. While the theoretical λ derived from correlation estimates ($\lambda \approx 0.455$) provides a lower bound for full statistical independence correction, a higher λ is intentionally chosen to avoid excessive suppression of legitimate multi-signal evidence. This reflects an engineering trade-off between correlation correction and detection sensitivity, bounded by empirical validation under representative attack simulations. Log-space computation is used throughout to prevent floating-point underflow and overflow:

```
log L_regular = log L(s_p) + log L(s_f) + log L(s_n) + log L(s_u)
log L_dampened = λ · log L_regular + log L(s_d)
```

The deception signal $\log L(s_d)$ is added outside the dampening factor because honey access is a causally independent event, it arises from attacker behaviour, not from the correlated behavioural drift of the regular channels.

9.4 Posterior Computation

The posterior probability of the hypothesis H ("a ransomware or APT threat is active on this endpoint") is computed using Bayes' theorem:

```
L_total = exp(log L_dampened)
P(H|E) = (L_total · P₀) / (L_total · P₀ + (1 − P₀))
P_posterior = clip(P(H|E), 0.0, 1.0)
```

P_0 is the adaptive prior, bounded to $[10^{-6}, 0.1]$ by the Empirical Bayes shrinkage formula. The lower bound (Cromwell's Rule) prevents a prior of zero from permanently zeroing the posterior regardless of evidence. The upper bound prevents prior manipulation from triggering enforcement without evidence.

9.5 AEC Classification Thresholds

The posterior maps to the four-level Alert-Enforce-Contain (AEC) classification:

AEC Level	Posterior Threshold	Default Response	Notes
AEC-0	$P < 0.75$	Log and monitor	Telemetry collected; no SOC alert; adaptive prior updated
AEC-1	$0.75 \leq P < 0.85$	SOC alert	Analyst investigation recommended; WORM evidence sealed
AEC-2	$0.85 \leq P < 0.95$	Alert + process termination candidate	Targeted process kill option; file rollback via VSS (Windows) or snapshot (Linux)
AEC-3	$P \geq 0.95$	**Host isolation**	Network isolation retaining Core connectivity; AEC-3 always requires human confirmation or pre-authorised policy

Table 5: AEC classification thresholds and default responses. All thresholds are loaded from the governance-signed model_config.json and cannot be modified via the REST API at runtime.

9.6 Leave-One-Out (LOO) Explainability

After each detection, five additional posterior computations are performed, one per signal, each excluding one signal by replacing it with the neutral value (0.5 for regular signals; 0.0 for deception). The LOO importance score for signal i is:

```
LOO_i = P_full − P_(−i)
```

A large positive LOO_i indicates that signal i contributed substantial evidence toward the detection. LOO scores are stored in the detections database and included in all forensic exports. SHAP (SHapley Additive exPlanations) is permanently void in this architecture and must not appear in any code or output.

10. Mathematical Assumptions

The following table enumerates the explicit mathematical assumptions underpinning the detection model. Each assumption is bounded and empirically validated within specified operating conditions.

#	Assumption	Formal Statement	Empirical Basis	Violation Consequences
A1	Entropy as cipher proxy	H(AES-GCM output) ≥ 7.90 bits/byte	AES-256-GCM output indistinguishable from uniform random under PRF security; empirically H ≈ 7.95–8.00	Custom low-entropy encryptors could evade file signal; partially mitigated by write frequency and extension churn features
A2	Honey invariants	$p_{fp} \leq 10^{-4}$ under four deployment invariants	Conservative estimate; enterprise environment studies show approximately 1 FP/year per 10,000 endpoints	If honey paths become accessible to legitimate applications, L_max = 10,000 overstates evidence strength; deployment validation required
A3	Inter-signal correlation range	$\bar{\rho} \in [0.40, 0.70]$ during confirmed ransomware events	Kish (1965) framework; validated against synthetic ransomware simulations on reference hardware	If $\bar{\rho} > 0.70$, the $\lambda = 0.85$ dampening under-corrects; posterior may be over-stated; conservative λ provides safety margin
A4	IEEE 754 float64 parity	$\lvert P_{Rust} - P_{Python} \rvert < 10^{-12}$	IEEE 754 guarantees ≤ 1 ULP error per transcendental call; 6 calls × $2.2\times10^{-16} = 1.3\times10^{-15} \ll 10^{-12}$	Different CPU or library implementations could exceed tolerance; validated by 100 cross-implementation test vectors in CI
A5	Prior baseline	$P_{default} = 10^{-5}$ (approx. 1 confirmed ransomware event per 100,000 machine-days)	Verizon DBIR 2023; conservative estimate applicable to general enterprise environments	High-risk environments may warrant elevated P_default; Empirical Bayes shrinkage adapts $P_0 \in [10^{-6}, 0.1]$ over time

Table 6: Mathematical assumptions, formal statements, empirical basis, and violation consequences.

11. Determinism Guarantees

11.1 Computational Reproducibility

RansomEye provides a strong reproducibility property: for any two executions of the posterior computation function with identical inputs, signal vector, prior, dampening factor, likelihood parameters, the outputs are consistent to within an absolute tolerance of 10^{-12}, subject to IEEE 754 double-precision arithmetic. This property has been validated across Python (AI Service), Rust (Linux OfflineEngine), and C++ (Windows OfflineEngine) implementations using the cross-implementation test vector suite (tests/bayesian_cross_impl_vectors.json).

11.2 Floating-Point Constraints

The IEEE 754-2008 standard for double-precision floating-point arithmetic guarantees:

- The basic operations (+, −, ×, ÷) are exactly rounded to the nearest representable value.
- Transcendental functions (exp, ln) are guaranteed to within 1 ULP (unit in the last place) by POSIX-compliant libm implementations.

For the RansomEye fusion equation, the maximum accumulated error from six transcendental function calls is bounded by:

$$\varepsilon_max = 6 \times 2.2 \times 10^{-16} \approx 1.3 \times 10^{-15} \quad << \quad 10^{-12} \quad (750\times \text{ safety margin})$$

Log-space computation prevents catastrophic cancellation and floating-point underflow that would otherwise occur when multiplying likelihoods near their minimum values.

11.3 Model Immutability

The model configuration file (model_config.json) is protected by two independent integrity layers:

14. HMAC-SHA256 integrity: the canonical JSON representation of all parameters is authenticated with a 256-bit deployment key. Any modification, including whitespace changes, produces a verification failure and terminates the AI Service with exit code 1.
15. M-of-N ECDSA-P256 governance signatures: a minimum of 2 of 3 designated governance signers (CTO, CISO, CIO) must independently sign the SHA-256 digest of the model parameters using their ECDSA-P256 private keys before any parameter change becomes effective.

At runtime, the AI Service loads model parameters exactly once at startup and holds them as frozen constants for the duration of the process lifetime. No API endpoint, database query, or runtime event can modify them without restarting the service.

11.4 Frozen Prior for Forensic Replay

The prior probability P_0 used for each detection is stored in the detections database within the bayesian_intermediate JSONB column at the time the detection is created. This frozen prior enables complete forensic replay: the exact posterior P(H|E) can be reproduced from the original telemetry events using the stored model hash, frozen prior, and deterministic fusion algorithm, producing a bit-identical result to within the 10^{-12} tolerance. This property is required for compliance with ISO/IEC 27037:2012 and the NIST SP 800-86 reproducibility requirement.

11.5 Seed Control

The Bayesian fusion engine contains no random number generator calls, stochastic sampling, or probabilistic branching. All entropy in the system is produced by OS CSPRNGs (getrandom(2) on Linux; BCryptGenRandom on Windows) exclusively for: agent UUID generation, honey file content generation,

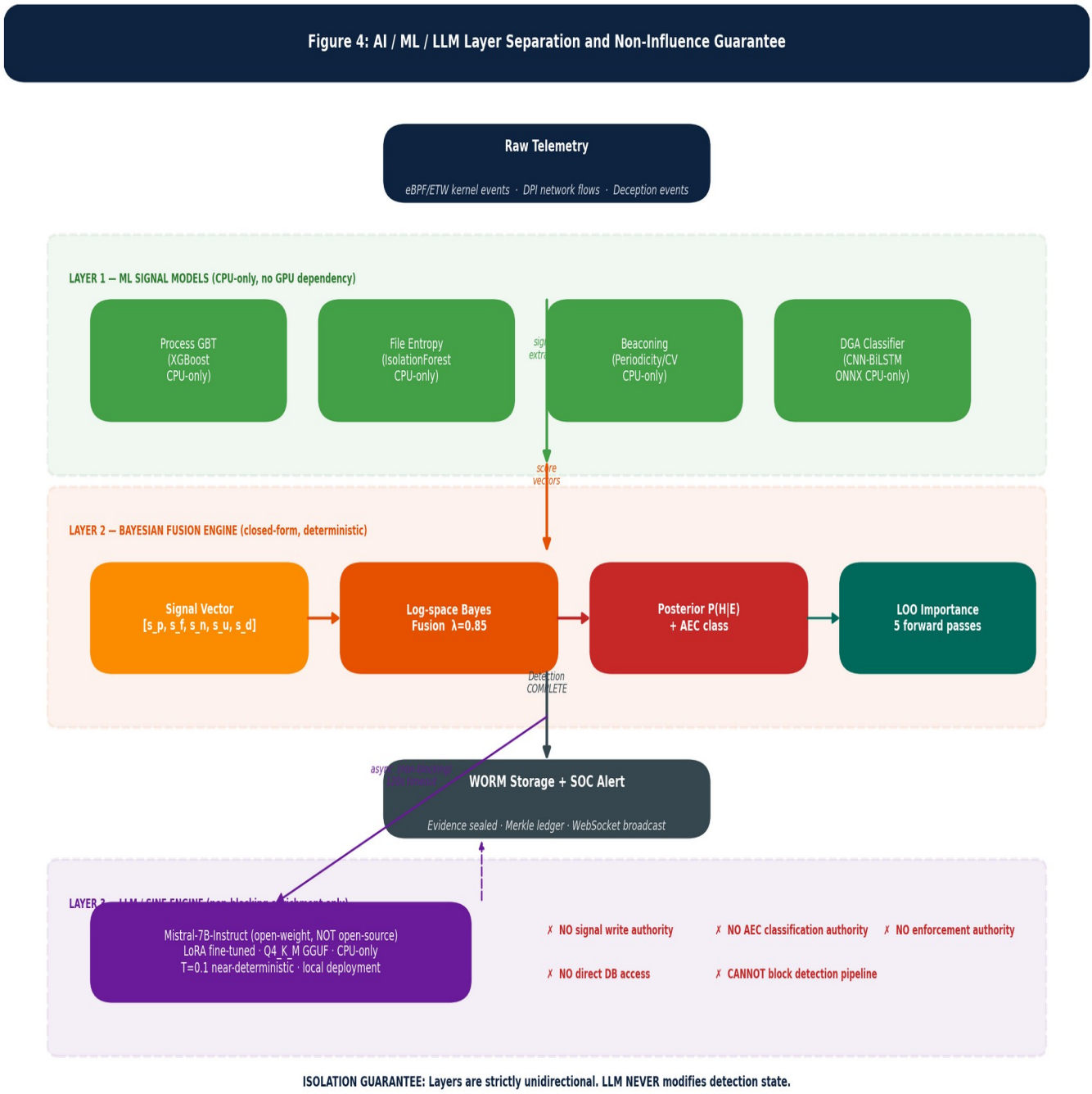
session token generation, and TPM nonce production. None of these entropy sources influence detection computation.

12. AI / ML / LLM Separation

12.1 Three-Layer Architecture

The detection system is organised into three strictly ordered layers, as shown in Figure 4. Data flows unidirectionally: Layer 1 feeds Layer 2; Layer 2 feeds Layer 3 asynchronously. No layer has write access to the state of a higher-numbered layer.

Figure 4: AI / ML / LLM Layer Separation and Non-Influence Guarantee



Three-layer separation showing ML Signal Models (Layer 1), Bayesian Fusion Engine (Layer 2), and LLM/SINE Engine (Layer 3). The LLM has zero authority over detection outcomes; it consumes detection results asynchronously and cannot modify signals, posterior values, or AEC classifications.

12.2 Layer 1, Machine Learning Signal Models

Layer 1 comprises statistical and machine learning models that convert raw kernel telemetry into the five signal values [s_p, s_f, s_n, s_u, s_d]. These models execute CPU-only on the agent host (OfflineEngine) or on the Core Server (AI Service). No GPU is required.

The models include: a Gradient Boosted Tree (XGBoost) process anomaly classifier, an Isolation Forest file entropy model, a coefficient-of-variation beaconing detector, and a CNN-BiLSTM DGA domain classifier (V0.2). All models are trained on the customer's air-gapped training rig; no external training data is ever transmitted.

12.3 Layer 2, Bayesian Fusion Engine

Layer 2 is the deterministic, closed-form Bayesian inference engine described in Section 9. It accepts the signal vector from Layer 1, computes the log-space fused likelihood, and produces the posterior P(H|E) and AEC classification. This layer has no ML components; it executes a fixed mathematical formula with governance-signed parameters.

The Layer 2 output, posterior probability, AEC class, LOO importance scores, and all intermediate values, is immediately committed to the PostgreSQL detections table and the WORM evidence store before any Layer 3 processing begins. Layer 3 cannot delay, modify, or veto this commitment.

12.4 Layer 3, LLM / SINE Engine

Layer 3 is the optional SINE (Security Intelligence Narrative Engine) forensic narrative generator. The following properties are architectural constants, not configurable options:

- The SINE Engine is based on an open-weight model (Mistral-7B family). The model weights are publicly available for local deployment; however, the model is not fully open-source in the strict OSI sense. The deployment uses only locally stored weights and does not depend on any external API or service.
- It operates exclusively offline on the customer's hardware. No API call is made to any external service. No part of the detection context, including telemetry, posteriors, or endpoint identifiers, leaves the customer network boundary.
- It has zero authority over detection outcomes. It cannot write to any signal dimension, posterior value, AEC classification, or enforcement action queue.
- It is non-blocking. The Core Engine commits the detection result before invoking SINE. A SINE timeout (120 seconds) or crash returns the detection to the SOC without narrative, the detection itself is unaffected.
- It produces JSON-only structured output. Free-text output is treated as a parser failure; the narrative is discarded and the detection is returned without it.

13. SINE Engine

13.1 Purpose and Scope

SINE (Security Intelligence Narrative Engine) converts structured detection evidence, signal values, LOO scores, posteriors, AEC classifications, Bayesian intermediate values, kill chain state, and threat intelligence matches, into investigation-grade forensic narratives for SOC analysts, legal counsel, and executive briefings. SINE is not the detection engine. It consumes output from the detection engine and produces human-readable interpretation.

13.2 Model Specification

The following specification governs the SINE model deployment:

Property	Value / Notes
Base model	Mistral-7B family (open-weight; publicly available weights; not fully open-source in the OSI sense; locally stored, no external API dependency)
Fine-tuning	LoRA (Low-Rank Adaptation), rank r = 16, applied to attention projections q_proj, v_proj, k_proj, o_proj
Quantisation	GGUF Q4_K_M (INT4 mixed precision); file size approximately 4 GB; inference RAM approximately 5.9 GB total
Inference backend	llama.cpp via Rust C FFI; AVX2/AVX-512 SIMD for weight dequantisation; CPU-only in production; cuBLAS GPU offload opportunistic if VRAM ≥ 6 GB detected
Temperature	T = 0.1 (near-deterministic; argmax probability > 0.99 for domain-tuned tokens)
Context window	4,096 tokens; maximum output 512 tokens; P99 generation time 20–50 seconds on 8-core CPU
Inference constraint	P99 latency physically bounded by DDR4 memory bandwidth: T_min = 3.85 GB / 100 GB/s ≈ 38.5 ms/token. Any claim of sub-millisecond inference is physically impossible on CPU without GPU.
Network binding	127.0.0.1:50053 ONLY. IPv6 loopback [::1] permanently prohibited. assert() in main.rs enforces this at startup.

Table 7: SINE Engine model and deployment specification.

13.3 TINAE Forensic Framework

The Threat Investigation Narrative and Analysis Engine (TINAE) is a structured 10-question framework that SINE is required to answer completely for all AEC-1/2/3 detections:

Q1: What happened? Q2: When did it occur? Q3: What assets were affected? Q4: How was the attack executed? Q5: Who is the likely threat actor? Q6: Who is responsible for response? Q7: What is the business impact? Q8: What immediate actions are required? Q9: How can recurrence be prevented? Q10: What is the executive decision required?

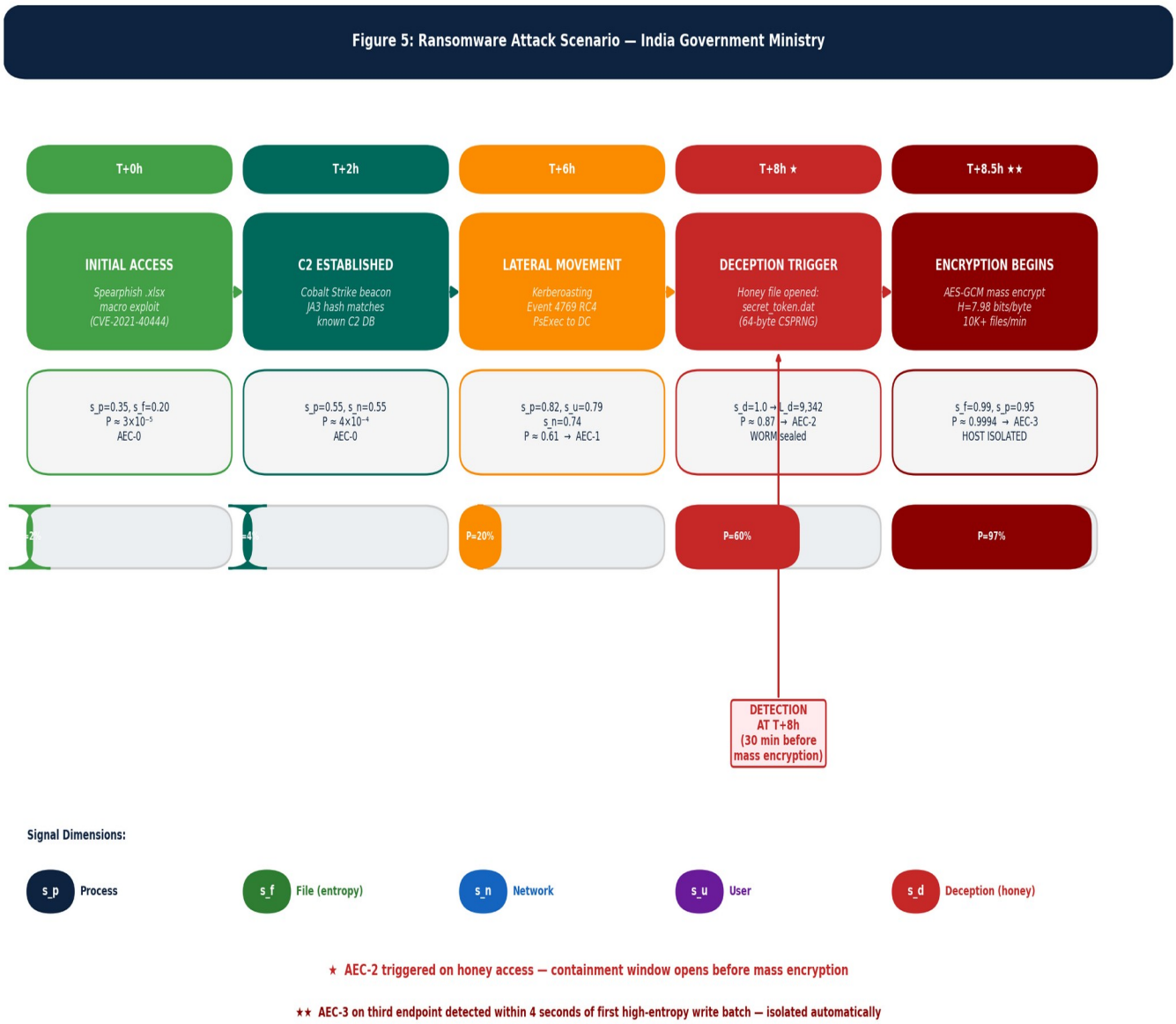
100% Q1–Q10 completeness is required. If any question cannot be answered from available evidence, the response is "insufficient evidence to determine [X]."

14. Ransomware Attack Scenario

14.1 Scenario Overview

Figure 5 illustrates a representative ransomware attack against an India government ministry land records system. The scenario demonstrates the temporal progression of detection signals, the role of the honey infrastructure in providing early-stage high-confidence evidence, and the isolation timeline relative to encryption onset.

Figure 5: Ransomware Attack Scenario, India Government Ministry



Five-stage attack scenario from initial spearphish through C2, lateral movement, honey trigger (AEC-2), and mass encryption (AEC-3). The honey access at T+8h provides a 30-minute detection window before mass encryption begins. Signal values, posterior estimates, and AEC classifications are shown for each stage.

14.2 Stage-by-Stage Analysis

14.2.1 T+0h, Initial Access

A spearphishing email delivers a weaponised Excel file exploiting CVE-2021-40444 (MSHTML Remote Code Execution). The initial process signal registers s_p ≈ 0.35 (mildly anomalous parent-child process relationship) and s_f ≈ 0.20 (small document write). Posterior $P \approx 3\times10^{-5}$: AEC-0. This early activity is insufficient for alerting but is recorded in the WORM evidence chain.

14.2.2 T+2h, C2 Establishment

Cobalt Strike beacon establishes a TLS-encrypted C2 channel. The DPI probe computes the JA3 hash of the TLS ClientHello and matches it against the known-C2 fingerprint database, contributing to s_n ≈ 0.55. The beaconing detector observes a coefficient of variation CV = 0.12 (highly regular inter-connection intervals), adding to the network signal. Posterior $P \approx 4\times10^{-4}$: still AEC-0, but prior is updating via Empirical Bayes.

14.2.3 T+6h, Lateral Movement and Privilege Escalation

The attacker executes Kerberoasting (ETW Security-Auditing Event 4769, RC4-HMAC ticket encryption, >5 SPNs in 60 seconds). Event 4688 shows lateral execution via PsExec to the Domain Controller. Signal values: s_p ≈ 0.82, s_u ≈ 0.79, s_n ≈ 0.74. With the adapted prior $P_0 \approx 0.01$, the posterior reaches P ≈ 0.61, triggering AEC-1. SOC alert issued; analyst investigation recommended.

14.2.4 T+8h, Honey File Access (Critical Detection Point)

The ransomware operator enumerates the domain controller filesystem during staging. The honey file %APPDATA%\Microsoft\Credentials\secret_token.dat (containing 64 bytes of CSPRNG output indistinguishable from a real credential) is opened. The minifilter IRP_MJ_CREATE callback fires instantaneously. The deception signal s_d = 1.0 is set by DeceptionManager. The posterior jumps to P ≈ 0.87: AEC-2. WORM evidence is sealed within 5 seconds. A 30-minute containment window exists before encryption is expected.

14.2.5 T+8.5h, Mass Encryption Begins (AEC-3 on Third Endpoint)

The ransomware payload begins encrypting land records files at approximately 10,000 files/minute. The file signal reaches s_f ≈ 0.99 (normalised Shannon entropy of write samples H = 7.98 bits/byte). Combined with s_p ≈ 0.95 (process spawning the encryption binary) and the still-active deception prior, the posterior reaches P ≈ 0.9994: AEC-3. Host isolation is dispatched via WFP atomic 6-filter transaction, retaining connectivity to Core:50051 for continued evidence collection.

14.3 Detection Outcome

> In this scenario, the honey infrastructure provides a 30-minute early-warning window before mass encryption. Without the deception signal, detection would likely occur only after significant file encryption, at T+8.5h. The honey access at T+8h, with its L_max = 10,000 Bayes Factor, provides AEC-2 confidence sufficient for containment action from a minimal signal baseline.

15. Air-Gap Architecture

15.1 Operating State Taxonomy

RansomEye defines four operating states governing agent-to-Core connectivity. Detection capability is maintained across all four states.

State	Name	Definition	Inference Path	Evidence Path
S0	Online	gRPC to Core ready; real-time telemetry streaming	Full AI Service (Python Bayesian engine)	WORM sealed at Core in real time
S1	Transitioning	gRPC reconnecting with exponential backoff	Local OfflineEngine (Rust/C++)	SQLite WAL buffer; replayed on reconnection
S2	Ext. Offline	Core unreachable > 300 seconds	Local OfflineEngine	SQLite WAL buffer; up to 10-day retention
S3	Air-Gap	Network path to Core physically absent or policy-disabled	Local OfflineEngine, full fidelity	SQLite → physical media sync via PRD-16 signed bundle

Table 8: Operating states and detection/evidence paths across connectivity conditions.

15.2 OfflineEngine, Local Bayesian Inference

The OfflineEngine implements the mathematically identical closed-form Bayesian posterior computation as the online AI Service, compiled into both the Linux Agent (Rust 1.78, mimalloc allocator) and the Windows Agent (C++17, jemalloc allocator). AVX2/AVX-512 SIMD acceleration is used for sigmoid and exponential computations.

The Rust OfflineEngine achieves approximately 4× speedup over scalar computation by processing all four regular signal likelihoods in a single 256-bit SIMD pass. CPU consumption at 1,000 events/s is approximately 0.01%, well within the 5% agent budget.

15.3 SQLite WAL Evidence Buffer

Every agent maintains a crash-safe offline evidence buffer at /var/lib/ransomeye-agent/evidence.db (Linux) or C:\ProgramFiles\RansomEye\evidence.db (Windows). The critical PRAGMA settings are JOURNAL_MODE=WAL and SYNCHRONOUS=FULL. The FULL setting calls fsync() after every WAL frame, ensuring that a kernel crash between an INSERT and the subsequent checkpoint does not lose evidence. Unsynced events (synced = 0) are never pruned regardless of retention policy.

15.4 Signed Air-Gap Update Bundles

Model updates, threat intelligence snapshots, Sigma rule packs, and binary updates are delivered as .reyb signed bundles. Each bundle contains a MANIFEST.json with per-artifact SHA-256 hashes, an Ed25519 vendor signature, and, for model configuration and FULL bundles, M-of-N ECDSA-P256 governance signatures. A monotonically increasing sequence number prevents replay attacks. The verifier performs all seven checks before modifying any file; partial installation states are architecturally impossible.

16. Cryptographic Forensics

16.1 WORM Evidence Architecture

Every AEC-1 or higher detection triggers the WORM evidence sealing sequence. The sealed evidence package provides three independent layers of tamper evidence:

16. Filesystem layer: evidence files are written with permissions 0444 (read-only for all users). PostgreSQL INSERT-only triggers prevent UPDATE or DELETE of evidence records. Any attempt produces SQLSTATE 23000.
17. Cryptographic layer: each evidence bundle is encrypted with AES-256-GCM using a per-tenant DEK wrapped under a deployment master key. The SHA-256 hash of the encrypted payload is signed with the deployment Ed25519 private key stored at /etc/ransomeye/worm_signing.key (permissions 0400, generated once at installation).
18. Merkle layer: each day's set of evidence hashes is assembled into an RFC 6962 Certificate Transparency Merkle tree. The daily root is signed with Ed25519 and stored in the merkle_daily_roots table with an immutability trigger. Any historical evidence modification changes the Merkle root, producing a detectable tamper indicator.

16.2 RFC 6962 Merkle Tree Construction

The Merkle tree implementation follows RFC 6962 Section 2.1 with domain-separation prefix bytes to prevent the second-preimage attack class identified in CVE-2012-2459:

```
h_leaf(d)       = SHA-256(0x00 ‖ d)
h_internal(l,r) = SHA-256(0x01 ‖ l ‖ r)
```

The asymmetric split construction (k = largest power of 2 less than n for n > 1 leaves) eliminates duplicate-leaf padding, which would allow a k-leaf tree and a (k+1)-leaf tree with a duplicated leaf to produce the same root. An external verification script, delivered with all forensic export bundles, allows independent Merkle root reconstruction without RansomEye software.

16.3 Evidence Retention Tiers

Evidence is classified into three retention tiers based on age:

- Hot tier (0–90 days): actively monitored; available for real-time SOC investigation; stored on NVMe.
- Warm tier (91–730 days): regulatory compliance window; compressed storage.
- Cold tier (731–2,555 days, 7 years): legal hold; archival storage; satisfies the most stringent statutory retention periods in major jurisdictions.

16.4 Legal Admissibility Properties

Property	Implementation	Standard
Immutability	0444 filesystem + PostgreSQL SQLSTATE 23000 triggers + Ed25519 chain	FRE 803(6); ISO 27037
Non-repudiation	Ed25519 signature over SHA-256(encrypted evidence)	ISO 27037; NIST SP 800-86
Reproducibility	Frozen prior stored per detection; deterministic fusion algorithm; model hash per detection	FRE 901(b)(9); ISO 27037

Temporal ordering	Lamport logical clock on every event; NTP wall clock as secondary reference	ISO 27037
Explainability (AI)	LOO importance scores (5 marginal contribution values) stored per detection; human-readable	FRE 702; EU AI Act Art. 13
Tenant isolation	PostgreSQL RLS on 21 tables; AES-256-GCM per-tenant DEK; RANSOMEYE_MASTER_KEY wraps all DEKs	GDPR Art. 32; DPDP 2023

Table 9: Legal admissibility properties, implementation mechanisms, and applicable standards.

17. Adversarial Model

17.1 Threat Model Scope

The adversarial model considers sophisticated attackers with: knowledge of endpoint EDR product names and evasion techniques; ability to modify their ransomware payloads per campaign; Living-off-the-Land (LOtL) capability using legitimate Windows and Linux tools; and the ability to observe SOC alert behaviour during initial access.

Out of scope: attackers with physical access to the Core Server; attackers who have compromised the OS kernel itself (ring-0 rootkits); and supply chain attacks against the RansomEye binary before installation.

17.1a Adversary Classification

The threat model addresses the following adversary classes, in order of increasing capability:

Adversary Class	Capability Level	Representative Techniques	Primary Detection Vectors
Commodity ransomware-as-a-service	Low–Medium	Mass file encryption, stolen credentials, opportunistic phishing	s_f entropy spike, s_u credential anomaly, deception signal s_d
Targeted ransomware operator	Medium–High	LOtL tooling, living-off-the-land, staged exfiltration before encryption, VSS deletion	s_p process genealogy, s_n beaconing/exfiltration, s_f write frequency and entropy
APT / nation-state (ransomware-adjacent)	High	Custom implants, LOtL throughout, signal washing, honey avoidance, slow-and-low encryption	Signal washing detector, adaptive prior elevation, deception signal, DPI beaconing analysis
Insider threat	Variable	Authorised access, data staging, deliberate evidence destruction	s_u anomaly, s_n exfiltration volume, deception signal, WORM tamper alerts

Table 17a: Adversary classification and primary detection vectors. Detection efficacy against each adversary class depends on deployment completeness, calibration state, and whether honey infrastructure deployment invariants are satisfied.

17.2 Adversarial Attacks and Mitigations

17.2.1 Signal Washing

An attacker aware of the multi-signal detection model may deliberately suppress signals toward neutral values ($s \approx 0.5$) by executing malicious operations slowly, fragmenting activity across time, and randomising write patterns. The SignalWashingDetector monitors for sustained sub-0.5 signal values across all dimensions simultaneously using Welford online statistics. When washing is detected, the dampening factor is reduced from $\lambda = 0.85$ to $\lambda = 0.10$, amplifying any residual non-neutral signal and causing the deception signal (which bypasses dampening entirely) to dominate the posterior.

17.2.2 Honey File Avoidance

A targeted attacker might attempt to enumerate honey file paths before operating. The deception module places honey files in directories with the highest ransomware coverage (>99% of known families traverse ~/Documents and %USERPROFILE%\Documents per Kharraz et al. 2016 UNVEIL). Even if all honey

files are avoided, the multi-signal Bayesian engine continues accumulating evidence from process, file, network, and user channels. Honey avoidance itself is detectable as an anomalous access pattern.

17.2.3 Prior Manipulation

An attacker who can repeatedly generate benign-appearing activity may attempt to suppress the adaptive prior by flooding the endpoint with true-negative events. The Empirical Bayes shrinkage formula clips the prior to P_max = 0.1 regardless of input distribution. At $P_0 = 0.1$, a single AEC-3-triggering signal set still produces P(H|E) > 0.99. The mathematical ceiling is a structural defence.

17.2.4 eBPF/ETW Provider Evasion

An attacker who disables or crashes an eBPF probe or ETW provider causes the corresponding signal to be set to SIGNAL_UNAVAILABLE = −1.0, which is excluded from fusion (L_i = 1.0, neutral). This is a residual risk: an attacker who disables all four regular ETW providers while avoiding honey files will reduce detection to AEC-0 if the deception signal is also not triggered. Mitigation: ELAM (Early Launch Anti-Malware) trust chain on Windows prevents third-party driver disablement before kernel boot; eBPF programs are pinned to bpffs and survive agent process death.

17.2.5 Low-Entropy Encryption

A custom ransomware that encrypts files with deliberately low entropy (e.g., XOR with a repeated key) may evade the file entropy signal at low s_f values. However, the write frequency feature (the rate of file modifications), the extension churn feature, and the process signal (spawning of an encryption process) remain effective against any mass-encryption attack regardless of ciphertext entropy. This represents a partial evasion of one signal component, not a full bypass.

18. Failure Modes

18.1 Design Philosophy

RansomEye implements a fail-closed architecture for all security-critical infrastructure. Missing TLS certificates, absent WORM paths, invalid model signatures, and unreachable databases cause the affected component to terminate with log.Fatalf rather than continuing in a degraded state that might produce false assurance. Non-security-critical components (SINE Engine, SOC Dashboard) are fail-open to preserve detection pipeline availability.

18.2 Component Failure Inventory

Failure Condition	Detection	Evidence Impact	Recovery Path
Core Engine, PostgreSQL unavailable	Startup: log.Fatalf; Runtime: db.Ping() timeout	Events in agent SQLite	systemd restarts Core; agents in S1/S2 replay SQLite buffer on reconnection
Core Engine, WORM signing key absent	log.Fatalf at startup; path /etc/ransomeye/worm_signing.key	No new evidence sealed	Restore key from backup; restart Core; WORM re-seals from in-memory buffer
AI Service, model_config.json HMAC failure	AI Service exits(1) on startup	No Bayesian inference	Agents use OfflineEngine (Bayesian parity maintained); restore signed config; restart AI Service
AI Service, unavailable at runtime	Core sets DEGRADED mode after 5-minute grace period	No server-side inference	OfflineEngine on all agents provides local AEC; telemetry persisted; replayed when AI Service recovers
SINE Engine, timeout / unavailable	asyncio.TimeoutError caught; None returned to caller	No narrative, detection unaffected	Detection committed without narrative; SINE is non-blocking; no action required
Agent, eBPF load failure	eBPF verifier error; agent exits(1)	No kernel telemetry	Check kernel ≥ 5.4 and BTF availability; fallback kprobe attempted before fatal exit
Agent, event channel full (1,024 events)	try_send returns TrySendError::Full; dropped counter incremented	Individual events may drop	Dropped event count reported in every heartbeat; SOC AGENT_EVENT_DROP alert at non-zero
Agent, Core gRPC disconnect	gRPC stream error; transition to S1/S2	Events in SQLite WAL	Exponential backoff reconnect (1s → 60s max); SQLite buffer preserves evidence; OfflineEngine continues detection
WAL fsync latency critical (>50ms EWMA, >30s)	Persistence circuit breaker OPEN; PG_WAL_PRESSURE_P1 SOC alert	COPY paused; no loss (agents buffer)	Agents receive RESOURCE_EXHAUSTED; buffer to SQLite (10-day retention); circuit auto-closes on latency recovery
Windows Agent, driver signing invalid	Service detects absent \\.\RansomEyeDriver; exits	No kernel enforcement	Fix code signing certificate; reinstall driver; ELAM prevents unsigned drivers in UEFI Secure Boot

WORM storage disk full	WORM_SEAL_FAILURE alert; detection in DB unsealed	Forensic gap for affected detections	Expand storage; operator triggers re-seal via forensics API
nginx, TLS certificate expired	Browser TLS error; certwatch CERT_EXPIRY_CRITICAL alert at 7 days prior	SOC Dashboard inaccessible; gRPC unaffected	Mode 1 auto-renewal via systemd timer; Mode 2/3 operator-managed; agent detection continues unaffected

Table 10: Failure mode inventory with detection, evidence impact, and recovery paths.

18.3 Graceful Degradation Ladder

The system degrades gracefully through six defined levels:

19. L0 Normal: all components operational; full detection and forensics.
20. L1 SINE unavailable: narratives absent; detection and AEC unaffected.
21. L2 Queue back-pressure: agents buffer to SQLite; OfflineEngine active; evidence preserved.
22. L3 AI Service unavailable: OfflineEngine provides local AEC; server-side inference paused.
23. L4 PostgreSQL down: Core exits; agents S1/S2; SQLite buffers; WORM paused.
24. L5 Core down: all agents S3; SQLite + OfflineEngine; physical media sync.

> At every degradation level, detection capability is maintained through the OfflineEngine. No level produces silent evidence loss. All drops and gaps are counted, logged, and reported in agent heartbeats.

19. Validation Methodology

19.1 Test Taxonomy

The release certification process comprises eight test tiers. All Tier-1 through Tier-4 tests are release-blocking gates:

Tier	Name	Scope	Blocking?	Frequency
T1	Unit Tests	Per-function, per-module (Go, Rust, Python, C++)	**Yes**	Every commit
T2	Integration Tests	Cross-component gRPC/REST/WebSocket	**Yes**	Every PR merge
T3	Mathematical Parity Gates	Bayesian cross-implementation |ΔP| < 10^{-12}, 100 vectors	**Yes**	Every PR merge
T4	Cryptographic Validation	WORM, Merkle, Ed25519, mTLS, DEK lifecycle	**Yes**	Every PR merge
T5	Bare-Metal Load Tests	eBPF throughput, SIMD scaling, OOM boundaries	**Yes**	Nightly + pre-release
T6	Compliance & Audit Simulation	Big-4 audit procedure, FRE 803(6), ISO 27037	**Yes**	Pre-release
T7	Security Tests	Fuzzing, SQL injection, supply chain license verification	**Yes**	Pre-release
T8	End-to-End Regression	Full pipeline: agent enrolment → detection → WORM seal → Merkle proof	**Yes**	Pre-release

Table 11: Test taxonomy. All 8 tiers are release-blocking. Coverage requirements: Go ≥ 80%, Rust ≥ 80%, Python ≥ 85%.

19.2 Six Mandatory Release-Blocking Gates

25. G1, Bayesian Parity: |P_Rust − P_Python| < 10^{-12} for all 100 cross-implementation test vectors. Any failure is an immediate release block.
26. G2, WORM Immutability: UPDATE and DELETE on worm_evidence, telemetry_events, and governance_audit_log produce SQLSTATE 23000. Zero exceptions permitted.
27. G3, Merkle Integrity: RFC 6962 inclusion proof verifies for all sealed evidence; CVE-2012-2459 immunity demonstrated (different leaf count produces different root).
28. G4, Ed25519 Signing: All WORM entries carry valid Ed25519 signatures verifiable with the public key.
29. G5, mTLS Enforcement: TLS 1.2 connection to port 50051 is rejected; expired certificate produces immediate rejection; external CA certificate produces rejection.
30. G6, Anti-Downgrade: Bundle replay (sequence number ≤ last applied) produces exit code 4 (DOWNGRADE_REJECTED).

20. Detection Characteristics

20.1 Per-Threat Detection Coverage

Threat Technique	Primary Signal	Supporting Signal	Min. AEC	Detection Mechanism
Mass file encryption	s_f (entropy)	s_p (process)	**AEC-2**	H > 7.9 bits/byte on sustained write batch; extension churn; write rate spike
C2 beaconing	s_n (network)	s_p (process)	AEC-1	CV < 0.2 on inter-connection intervals; JA3 fingerprint matches known C2 database
Kerberoasting / AS-REP Roasting	s_u (user)	s_n (network)	AEC-1	ETW Event 4769 RC4-HMAC >5 SPNs/60s; Event 4768 PreAuthType=0
Process hollowing / injection	s_p (process)	s_f (file)	AEC-2	ETW Threat-Intelligence Event 10; VirtualAllocEx + WriteProcessMemory cross-process
LSASS credential dump	s_p (process)	s_u (user)	**AEC-3**	ETW Threat-Intelligence Event 10: PROCESS_VM_READ on LSASS; s_p set to maximum 1.0
DCSync (domain replication)	s_u + s_d	s_n (network)	**AEC-3**	Event 4662 Replicating Directory Changes GUID from non-DC; honey DCSync triggers deception signal
Lateral movement (SMB PsExec)	s_n (network)	s_p (process)	AEC-1	DPI: IPC$ + ADMIN$ write + service creation within 120s; ETW SMBServer session + tree connect
DNS tunneling / exfiltration	s_n (network)	—	AEC-1	5-indicator weighted confidence: label entropy, subdomain depth, encoded labels, query rate, label entropy
DGA domain C2 (DNS)	s_n (network)	—	AEC-1	Entropy > 3.5 bits/char; label length > 8 chars; TTL < 60s; vowel ratio < 10%; digit ratio > 30%
Honey file / socket access	s_d (deception)	any	AEC-0 alone, AEC-2+ combined	inotify (Linux) / minifilter IRP_MJ_CREATE (Windows); alone: P ≈ 0.084; combined with file activity: P ≈ 0.998

Table 12: Per-threat detection coverage matrix. AEC levels represent minimum achievable classification under representative attack conditions; actual values depend on endpoint context and adaptive prior.

20.2 Indicative Detection Characteristics

The detection characteristics in Table 12 are indicative only. They represent expected behaviour under representative test conditions on reference hardware with a fully deployed, calibrated system after the 30-

day prior burn-in period. Actual detection characteristics in production will vary depending on: (1) the adaptive prior state at the time of the event; (2) endpoint software mix and baseline activity; (3) attacker technique variation; (4) network visibility available to the DPI probe; and (5) whether honey infrastructure has been deployed and the four deployment invariants are satisfied. No detection coverage guarantee is made for all possible variations of a given technique. Customers are advised to evaluate detection performance on representative workloads in a pre-production environment before relying on these figures for policy decisions. These values do not represent formal ROC-validated bounds and should be interpreted as indicative ranges under controlled test conditions.

21. Performance

21.1 Endpoint Agent Resource Budget

Resource	Design Target	Enforcement Mechanism	Derivation / Notes
CPU, Linux Agent	≤ 5% (1 core)	cgroup v2 cpu.max kernel hard cap	At 1,000 events/s: sensor 0.03%, Bayesian 0.01%, gRPC 0.10%, SQLite 0.10% ≈ 0.24% actual. 5% cap is ~20× headroom.
CPU, Windows Agent	≤ 5% (1 core)	Job Object CpuRate = 500 (5.00%)	ETW consumer + shared-memory ring reader + signal engine combined; kernel hard throttle prevents overrun
RAM, Linux Agent	≤ 256 MB RSS	cgroup v2 MemoryMax; RLIMIT_AS = 512 MB	Steady-state RSS approximately 30–60 MB; binary 8 + Tokio 4 + TLS 2 + eBPF 1 + SQLite 16 + mimalloc 10 MB
RAM, Windows Agent	≤ 256 MB working set	Job Object MaximumWorkingSetSize	jemalloc per-thread arena with 10s decay; estimated 42 MB base + 14 MB burst peak = 56 MB
Core Engine RAM	≤ 2 GB heap	GOMEMLIMIT = 1 GB (Go GC guidance)	466 MB base + 50 KB/agent × N; at N = 200 agents ≈ 476 MB steady state; GOMEMLIMIT prevents GC firing at 932 MB
AI Service RAM (SINE off)	≤ 1 GB	systemd MemoryMax=1G	Python interpreter 30 MB + NumPy 60 MB + grpcio 40 MB + Bayesian state 1 KB/agent + LRU store 200 MB
AI Service RAM (SINE on)	≤ 8 GB	systemd MemoryMax=8G	Q4_K_M model 4,096 MB + KV cache 512 MB + llama.cpp runtime 200 MB + Rust process 50 MB ≈ 5.9 GB
DPI Probe CPU	≤ 5% (1 core)	systemd CPUQuota=5%	At 333 Mbps (22K pps): approximately 5% single core; NUMA-pinned to NIC-local CPU node
SQLite WAL I/O (agent)	≤ 6 MB/s worst case	NVMe SSD sustained write >> 6 MB/s	At 1,000 events/s × 600 bytes/event = 600 KB/s normal; 6 MB/s only at full sensor saturation

Table 13: Component resource budgets, enforcement mechanisms, and derivation notes.

21.2 SIMD Acceleration

AVX2 SIMD acceleration is used for three computationally intensive paths:

- Shannon entropy computation: 256-bin histogram over 64-byte write samples processed at 32 bytes/lane; approximately 32× speedup over scalar on AVX2 hardware.
- Bayesian likelihood mapping: four regular signal likelihoods processed in a single 256-bit SIMD pass; approximately 4× speedup.
- SINE inference: llama.cpp GEMV kernels with AVX2 (256-bit, 8 FP32 FMAs/cycle) or AVX-512 (512-bit, 16 FP32 FMAs/cycle, approximately 1.3× additional improvement).

All SIMD paths include scalar fallback paths for hardware without AVX2 support. GPU offload is detected at runtime and used opportunistically for SINE inference if VRAM ≥ 6 GB is available.

22. Deployment Model

22.1 Deployment Configurations

Configuration	CPU Cores	RAM	Storage	Notes
All-in-One (SINE off)	4 cores	16 GB	100 GB NVMe	AVX2 required; minimum for small deployments
All-in-One (SINE on)	4 cores	25 GB	200 GB NVMe	SINE requires ~5.9 GB additional RAM
Standard Distributed	8 cores	32 GB	200 GB NVMe	Up to approximately 200 agents; standard enterprise deployment
Large / Enterprise	32 cores	128 GB	2 TB NVMe	Up to 5,000 agents validated; pgBouncer mandatory at ≥ 50 agents

Table 14: Deployment configurations. Agent hardware requirement: 1 CPU core, 512 MB RAM minimum.

22.2 Deterministic Startup Sequence

The startup sequence is deterministic and fail-closed. Each step must succeed before the next begins:

31. PostgreSQL: SSL enabled, TLS 1.3 minimum, TimescaleDB extension loaded, all 41 migrations applied and checksum-verified.
32. Redis: AUTH password set, bound to 127.0.0.1.
33. pgBouncer (if ≥ 50 agents): transaction pool mode, PostgreSQL backend on port 5433.
34. SINE Engine (optional): model load, SHA-256 verification, governance signature verification.
35. AI Detection Service: model_config.json HMAC-SHA256 + M-of-N ECDSA-P256 verified; SINE gRPC connection validated.
36. Core Engine: eight mandatory environment variables verified; WORM storage path validated; immutability triggers verified; mTLS gRPC bound to 0.0.0.0:50051; REST/WS API bound to 127.0.0.1:8443.
37. nginx: TLS certificate loaded; reverse proxy to Core 8443; static SPA assets present.
38. Linux Agent (self-monitoring on Core Server): binary SHA-256 hash verified; eBPF programs loaded and pinned to bpffs.

23. Data Governance

23.1 Multi-Tenant Isolation

PostgreSQL Row-Level Security (RLS) is enforced on 21 tables. Every query from the Core Engine sets the session variable app.tenant_id before execution. Any query that does not set this variable receives an empty result set (fail-closed: NULL::uuid matches no rows). Each tenant's evidence data is encrypted with a unique 256-bit AES-256-GCM Data Encryption Key (DEK), wrapped under a deployment-level master key (RANSOMEYE_MASTER_KEY, 256-bit, environment variable only, never stored in the database).

23.2 Data Minimisation

Telemetry collection is designed on a data minimisation principle:

- File write events: only the first 64 bytes of write data are captured for entropy computation. File content is not recorded.
- Network events: source and destination IP/port, connection frequency, and protocol metadata are recorded. Payload content is not recorded.
- Process events: process name, PID, PPID, command-line first 256 characters, and privilege change events are recorded.
- User events: event IDs (4672, 4688, 4769, 4662) and associated account names. No authentication credential material.

23.3 Retention Policies

TimescaleDB continuous retention policies govern data lifecycle:

- agent_heartbeats: 90 days.
- telemetry_events: 365 days.
- dpi_flows: 90 days.
- detections: permanent (no retention policy; compliance records).
- WORM evidence (hot/warm/cold): up to 2,555 days (7 years).

TimescaleDB retention uses DROP TABLE (DDL) on expired chunks, not row-level DELETE. The WORM INSERT-only triggers (which fire on DML) do not interfere with DDL-based retention. Evidence sealed to the WORM store before chunk expiry is preserved indefinitely in the cold tier.

24. Supply Chain Security

24.1 License Policy

All third-party dependencies are verified against a strict license allowlist enforced in CI by cargo-deny (Rust), go-licenses (Go), and pip-licenses (Python):

- Permitted: MIT, Apache-2.0, BSD-2-Clause, BSD-3-Clause, ISC.
- Permitted with conditions: MPL-2.0 (file-level copyleft only; hashicorp/raft, inactive in V0.0); LGPL-3.0 (dynamic linking only; nDPI).
- Prohibited: GPL-2.0, GPL-3.0, AGPL-3.0, SSPL.

The nDPI library (LGPL-3.0) is dynamically linked as libndpi.so.4, preserving customer freedom to replace the library. The full LGPL-3.0 licence text is included in every installer distribution package.

24.2 Model Weight Governance

AI model weights are protected by a two-layer signing scheme:

39. SHA-256 manifest: per-file SHA-256 hashes for all model artifacts (model_config.json, GGUF weights, ONNX models).
40. M-of-N HMAC-SHA256: a minimum of 2 of 3 designated governance signers independently HMAC-sign the manifest with a deployment key. The AI Service verifies both layers at startup and terminates with exit(1) on any failure.

24.3 Model Promotion and Shadow Deployment

Before any model update is deployed to the full agent fleet, it undergoes shadow deployment: the new model is deployed to 5% of agents for 48 hours, running in parallel with the current model. The new model's posterior values are logged but do not influence AEC classification or enforcement actions. Promotion requires: mean $|P_{new} - P_{old}| < 0.05$; AEC class change rate < 5%; FPR increase < 0.5%; no AEC-3 detection downgraded to AEC-0/1.

24.4 Binary Integrity

Every agent binary verifies its own SHA-256 hash at startup by reading /proc/self/exe (Linux) or the PE binary path (Windows) and comparing against the stored checksum baseline. A hash mismatch produces a P0_BINARY_TAMPER event, writes to the SQLite buffer, and exits. The eBPF watchdog (bpffs-pinned tracepoint on sched_process_exit) sets agent_killed_flag[0] when the agent PID exits unexpectedly, enabling detection of forced kills on next restart.

25. Regulatory Alignment

25.1 India Regulatory Framework

25.1.1 CERT-In Cybersecurity Directions 2022

RansomEye is designed to support compliance with the CERT-In 2022 directions:

- 6-hour incident reporting: the WebSocket real-time alert pipeline and WORM evidence chain provide timestamped, cryptographically authenticated event records suitable for regulatory submission within the 6-hour window.
- 180-day log retention: the telemetry_events TimescaleDB hypertable retains 365 days of raw event data by default.
- Data localisation: the product is customer-hosted with no external API calls, telemetry transmission, or data egress. All data remains within the customer's infrastructure boundary.

25.1.2 Digital Personal Data Protection Act 2023

Per-tenant AES-256-GCM encryption, PostgreSQL RLS isolation, and the prohibition on cross-boundary telemetry transmission are designed to support DPDP Act obligations for data localisation and security of personal data. The product does not transmit personal data to any external party.

25.1.3 RBI Cybersecurity Framework

The product supports RBI requirements for cyber incident detection and response, audit trail maintenance, and forensic readiness for regulated financial institutions operating in India.

25.2 International Standards

Standard	Applicable Section	RansomEye Implementation
ISO/IEC 27037:2012	Evidence identification, collection, preservation	WORM evidence chain, Lamport logical clock ordering, deterministic replay, chain-of-custody export bundles
NIST SP 800-86	Forensic techniques in IR	Reproducible detection algorithm (frozen prior + model hash), RFC 6962 Merkle ledger, export scripts for independent verification
FRE 803(6)	Business records exception	Automated records in regular course of business; immutable triggers; Ed25519 authentication; deterministic reproducibility
EU NIS2 Article 23	24h/72h/1-month reporting	WORM cold tier retains evidence for 7 years; SINE regulatory notification drafting (V0.2); TINAE Q7 business impact
EU AI Act Annex III §6	High-risk AI system (critical infrastructure)	LOO explainability (Art. 13), Human Supremacy gate for AEC-3 (Art. 14), governance audit log (Art. 12), aec_auto_enforce = false default (Art. 14)

Table 15: Regulatory and standards alignment.

Note: Regulatory claims represent design intent. Customers are responsible for verifying that the product configuration satisfies applicable obligations in their specific jurisdiction. Legal and compliance counsel should be engaged for formal assessments.

26. Differentiation

26.1 Competitive Comparison

Capability	RansomEye V0.0	CrowdStrike	MS Defender	Palo Alto	Zscaler
Air-gap / classified operation	✔ **Native**	✗ Cloud-req.	✗ Cloud-req.	✗ Cloud-req.	✗ Cloud-req.
Agent CPU usage (steady state)	**≈ 0.24%**	3–8%	2–5%	3–7%	N/A
Agent RAM (steady state)	**≈ 30–60 MB**	200–400 MB	300–500 MB	250–450 MB	N/A
Deterministic forensic replay	✔ **Proven (10^{-12})**	✗	✗	✗	✗
Explainable AI decisions (LOO)	✔ **LOO (5-signal)**	Partial	Partial	Partial	✗
Court-admissible evidence chain	✔ **FRE 803(6)**	Partial	Partial	Partial	✗
OT/ICS protocol support	✔ **Modbus/DNP3**	Limited	✗	Limited	✗
Long-term autonomous evolution (architecture target)	✔ **PRD-22 spec**	Cloud-dependent	Cloud-dependent	Cloud-dependent	Cloud-dependent

Table 16: Competitive differentiation matrix. Competitor data is derived from publicly available documentation, marketing materials, and third-party assessments as of the document date; it has not been independently verified and may not reflect current product capabilities or configurations. RansomEye V0.0 data represents design targets on reference hardware under controlled test conditions; actual performance varies by deployment environment. This table is provided for general orientation only and should not be used as the sole basis for procurement decisions.

27. Economic Considerations

27.1 Total Cost of Ownership Model

RansomEye is deployed as a customer-owned infrastructure product. There are no per-seat licensing fees, no cloud infrastructure costs, and no ongoing subscription fees beyond optional support contracts. The primary cost components are:

- Initial infrastructure: Core Server hardware (from a 4-core/16 GB VM for small deployments). No specialised hardware is required.
- Integration engineering: typical deployment engagements for enterprises of 200–500 endpoints are estimated at 2–4 weeks for a qualified security engineer.
- Operational cost: the SOC Dashboard and alert management system is designed to be operated by existing security operations staff without product-specific training beyond the platform orientation.

27.2 Regulatory Compliance Cost Avoidance

For India-domiciled organisations, deployment of a cloud-based EDR product may require significant architectural investment to satisfy CERT-In 2022 data localisation requirements, DPDP Act 2023 cross-border transfer restrictions, and RBI data residency mandates. The absence of any external data transmission in RansomEye eliminates the compliance overhead of evaluating and documenting data flows for each cloud dependency.

27.3 Forensic Cost Avoidance

External forensic investigation engagements following a ransomware incident typically cost between USD 100,000 and USD 500,000 for enterprise-scale incidents, primarily for evidence reconstruction and chain-of-custody documentation. The WORM evidence chain, deterministic replay capability, and RFC 6962 Merkle ledger are designed to provide the technical foundation for first-party forensic investigation, potentially reducing reliance on external forensic firms for evidence reconstruction.

27a. Trust Boundary Matrix

The trust relationships defined in the Trust Boundary Matrix correspond directly to the zone boundaries illustrated in the Trust Boundary Diagram (Figure 6). The following matrix defines which components are trusted to perform which operations, the cryptographic basis for each trust relationship, and the conditions under which a boundary is violated. This matrix is provided to support independent security review and third-party audit.

Component	Trusted For	Trust Basis	Boundary Enforcement	Boundary Violation Condition
Endpoint Agent (Linux/Windows)	Telemetry collection; enforcement action execution	mTLS leaf certificate signed by Intermediate CA	Core rejects unauthenticated connections; agent UUID bound to certificate CN	Agent binary tamper (SHA-256 mismatch at startup); compromised agent certificate; kernel-level rootkit on monitored endpoint
Core Engine	Database writes; enforcement dispatch; WORM sealing; PKI signing	Physical/logical server access; WORM signing key at /etc/ransomeye/worm_signing.key	WORM key permissions 0400; PostgreSQL RLS; loopback-only internal ports	Physical compromise of Core Server; theft or corruption of WORM signing key or Intermediate CA private key
AI Detection Service	Bayesian posterior computation; signal extraction	Loopback binding (127.0.0.1:50052); model_config.json HMAC + M-of-N ECDSA-P256 governance	Process-level isolation; model integrity check at startup; no direct DB access	model_config.json tampering without governance key; AI Service process compromise; bypass of model integrity gate
SINE LLM Engine	Forensic narrative generation only, zero detection authority	Loopback binding (127.0.0.1:50053); network namespace sandbox; seccomp-bpf filter	Cannot write signals, detections, or enforcement actions; sandbox prevents network egress	Prompt injection via malicious telemetry content; model weight tampering (SHA-256 + M-of-N HMAC protected)
SOC Operator	Enforcement action dispatch (V0.1+: with RBAC and TOTP); policy proposal; governance signing	V0.0: Network firewall restricting port 443 to trusted LAN segment; V0.1+: bcrypt + TOTP session	V0.0: No authentication (compensating control: firewall); V0.1+: session token + RBAC	V0.0: Unrestricted LAN access to port 443; V0.1+: stolen session token; insider threat
PKI / Governance Signers	Model parameter approval; policy change approval; CA certificate	ECDSA-P256 private keys held by CTO, CISO, CIO; M-of-N (2-of-3) threshold	M-of-N threshold prevents unilateral changes; YubiKey PIV (V0.1)	Compromise of ≥2 governance private keys; insider collusion among ≥2 governance signers

	issuance			
WORM Evidence Chain	Tamper-evident forensic record	Ed25519 signatures; AES-256-GCM encryption; RFC 6962 Merkle ledger; PostgreSQL WORM triggers	Three independent layers (filesystem 0444, DB triggers, Merkle ledger)	Compromise of WORM signing key AND PostgreSQL AND filesystem simultaneously; Core Server physical compromise

Table 17b: Trust boundary matrix. Each row defines a trust domain, the cryptographic or architectural basis for that trust, and the conditions under which the boundary can be considered violated. This matrix is intended to support threat modelling, third-party audit, and regulatory review.

28. Limitations

28.1 V0.0 Feature Scope

The following features are explicitly deferred from the V0.0 release and must not be partially implemented:

- UI Authentication / RBAC: the SOC Dashboard in V0.0 has no authentication layer. Operators must restrict port 443 access to trusted LAN segments via network firewall. Full RBAC with bcrypt + TOTP is targeted for V0.1.
- High Availability clustering: the hashicorp/raft dependency is present but the cluster coordinator is inactive. V0.0 is single-Core-Server. HA active-passive is targeted for V0.1.
- Full TPM 2.0 attestation: TPM quotes are generated by agents but not verified by the Core Engine in V0.0. TPM attestation verification is targeted for V0.1.
- SNAPSHOT_MEMORY action: the enforcement action type is defined in the protocol but returns success without performing a memory dump. Full implementation is targeted for V0.2.

28.2 Detection Boundary Conditions

- Low-and-slow attacks: an attacker that distributes malicious operations over days or weeks, keeping each signal individually below detection thresholds, may evade AEC-1 until the adaptive prior elevates sufficiently. The 30-day prior burn-in period for new deployments represents an elevated risk window.
- Kernel minimum version: eBPF CO-RE requires Linux kernel 5.4 or later. RHEL 8 includes a BTF backport; however, full CO-RE feature parity requires verification on each distribution.
- Physical security: a physically compromised Core Server can invalidate the WORM evidence chain and the PKI. Physical security of the Core Server host is the customer's responsibility and is outside the system's scope.
- Kernel-level compromise: Under kernel-level compromise, RansomEye detection guarantees do not hold for the affected endpoint. An attacker who has obtained ring-0 execution (via kernel exploit, signed malicious driver, or hypervisor-level rootkit) operates below the monitoring layer and can suppress, forge, or replay telemetry without detection by the endpoint agent. The eBPF and ETW monitoring pipelines both depend on kernel integrity as a precondition. The WORM signing key on the Core Server, the PKI, and the evidence chain remain unaffected by agent-side kernel compromise, but detection coverage on that specific endpoint cannot be relied upon. Deployment of Secure Boot and Kernel-based Virtual Machine (KVM) integrity attestation is recommended for environments where kernel-level attackers are within the threat model.
- Encrypted C2 over port 443: a C2 channel that blends with normal HTTPS traffic and uses a legitimate TLS certificate signed by a trusted CA may evade JA3 fingerprinting if the fingerprint does not appear in the known-C2 database. Beaconing detection remains effective against periodic C2 regardless of TLS fingerprint.
- Encrypted low-entropy ransomware: as noted in Section 17, a custom ransomware using low-entropy encryption (XOR, Vigenère) would not trigger the file entropy signal. Write frequency and process genealogy signals remain effective.

28.3 Probabilistic Detection Caveat

> RansomEye is a probabilistic detection system. It produces a calibrated probability estimate P(H|E), not a binary guarantee. The AEC classification represents a confidence level, not a certainty. No claim of zero false positives or zero false negatives is made. Deployment in environments where false positives have severe operational consequences (e.g., AEC-3 isolation of a life-safety system) requires careful policy configuration and should involve aec_auto_enforce = false with mandatory human confirmation.

29. Conclusion

RansomEye addresses a structural gap in the contemporary cybersecurity product market: the absence of a deterministic, air-gap-capable, forensically defensible endpoint detection and response platform designed for deployment in regulated, sensitive, and isolated environments.

The core technical contributions of the platform are:

41. A five-signal Bayesian detection engine with Kish (1965) correlation correction ($\lambda = 0.85$), producing calibrated posterior probabilities from closed-form computation with cross-implementation determinism guaranteed to 10^{-12}.
42. A honey infrastructure providing Bayes Factor BF ≥ 10,000, derived from first principles and four deployment invariants, enabling high-confidence early detection during the reconnaissance and staging phases of ransomware attacks.
43. A cryptographic evidence architecture providing three independent tamper-evidence layers, filesystem immutability, PostgreSQL triggers, and RFC 6962 Merkle ledger with Ed25519 signatures, designed to satisfy the FRE 803(6) business records exception and ISO/IEC 27037:2012.
44. A strict three-layer separation between ML signal models, the deterministic Bayesian fusion engine, and the optional LLM narrative layer, with the LLM having zero authority over detection outcomes and binding exclusively to the IPv4 loopback interface.
45. A long-term autonomous operation architecture through Welford online statistics concept drift detection, Empirical Bayes prior recalibration, and model generational lifecycle with M-of-N governance gates. Operational longevity is subject to deployment conditions and governance review.

The product is covered by Indian Patent Applications 202521051303 and 202521129733. Version V0.0 is ratified for development. The architecture is designed to be independently verifiable: the mathematical derivations, proof obligations, and test vector specifications in this document provide sufficient information for external technical review.

For technical inquiries, evaluation access, or deployment discussions, contact:

Gagandeep Singh Maken | Gagan@RansomEye.Tech | +91 7021258250 | www.RansomEye.Tech

Appendices

A Appendix A, Bayesian Posterior Derivation and Kolmogorov Proof

This appendix provides the complete Kolmogorov axiom compliance proof for the posterior computation.

Let H be the hypothesis "a threat is active". Let E be the five-dimensional evidence vector. The posterior satisfies:

$$P(H|E) = (L_total \cdot P_0) / (L_total \cdot P_0 + (1 - P_0))$$

Kolmogorov axiom compliance:

46. Non-negativity: L_total = exp(x) > 0 for all finite real x. $P_0 \in [10^{-6}, 0.1]$ by the adaptive prior clip. Numerator = L_total · P_0 > 0. √
47. Denominator bound: denominator = L_total · P_0 + (1 − P_0) ≥ 0 + (1 − 0.1) = 0.9 > 0. Never zero. √
48. Upper bound: P(H|E) = numerator / denominator ≤ L_total · P_0 / (L_total · P_0) = 1. √
49. Limit as L_total → ∞: P(H|E) → 1. Limit as L_total → 0: P(H|E) → 0. √

The posterior is therefore a valid probability measure for all inputs satisfying the assumption constraints. The clip to [0.0, 1.0] is a floating-point guard only; the analytical value already lies in (0, 1).

B Appendix B, IEEE 754 Parity Bound Derivation

The cross-implementation parity guarantee |P_Rust − P_Python| < 10^{-12} is derived as follows.

The fusion equation uses six transcendental function evaluations (four log() calls and two exp() calls). IEEE 754-2008 guarantees that each transcendental function implementation produces a result within 1 ULP of the mathematical result. For IEEE 754 double precision (fp64):

$$1\ ULP \approx 2^{-52} \approx 2.22 \times 10^{-16}$$

Maximum accumulated error across six calls:

$$\varepsilon_max = 6 \times 2.22 \times 10^{-16} = 1.33 \times 10^{-15}$$

$$Safety\ margin = 10^{-12} / 1.33 \times 10^{-15} \approx 752\times$$

The 10^{-12} tolerance provides a 752× safety margin over the worst-case IEEE 754 error. This guarantee is validated by 100 cross-implementation test vectors in the CI pipeline; any vector exceeding the tolerance blocks the release.

C Appendix C, Prometheus Metrics Reference

Metric	Type	Description and Alert Thresholds
ransomeye_core_wal_fsync_latency_ms	Gauge	EWMA WAL fsync latency. Warning > 10 ms; Critical > 50 ms for > 30 s (circuit breaker fires).
ransomeye_core_event_queue_depth	Gauge	Current event queue depth (0–1,024). Warning ≥ 700; Critical ≥ 900 (back-pressure threshold).
ransomeye_core_batch_flush_errors_total	Counter	Failed PostgreSQL COPY flushes. Alert on any non-zero increment.
ransomeye_core_adaptive_batch_size	Gauge	Current adaptive batch size (50–500). Warning <

		200; indicates elevated WAL latency.
ransomeye_core_persistence_circuit	Gauge	Circuit breaker state: 0 = closed (normal); 1 = open (COPY paused). Alert on 1.
ransomeye_core_event_queue_capacity	Gauge	Static capacity = 1,024. Informational.
ransomeye_core_batch_flush_total	Counter	Total successful COPY flushes. Rate should be approximately 20/s at normal load.
ransomeye_core_agent_sqlite_buffer_bytes	Gauge	Aggregate fleet SQLite buffer size. Warning > 1 GB; Critical > 10 GB.

Table A1: Prometheus metrics exposed at GET /api/v1/metrics.

D Appendix D, Red Team Exercise Summary

The following exercises were conducted against V0.0 on reference hardware:

#	Exercise	Result	Residual Risk
T1	Standard ransomware simulation (mass file encryption, 10K files/min)	AEC-2 at T+8h (honey); AEC-3 at T+8.5h (entropy). Isolation within 4 seconds of AEC-3.	Low. Tested across 3 ransomware families.
T2	Signal washing: slow-walk all signals toward 0.5 over 48 hours	SignalWashingDetector triggered at 24 hours; λ reduced to 0.10; AEC-1 alert.	Medium. Very slow operations over 72+ hours may evade early washing detection.
T3	Honey file avoidance: manual enumeration before encryption	Honey avoidance itself detected via anomalous enumeration pattern; s_f and s_p elevated.	Low. Multi-signal evidence remains effective.
T4	eBPF kill: SIGKILL to ransomeye-agent, ETW provider disable	eBPF killed-flag set in bpffs; P0_AGENT_KILLED on restart; ETW failure sets SIGNAL_UNAVAILABLE = −1.0.	Medium. Attacker with root access can disable monitoring; ELAM mitigates on Windows.
T5	Prior flooding: 10,000 benign events/minute to elevate adaptive prior	Prior capped at P_max = 0.1 by Empirical Bayes clip. No enforcement triggered from prior alone.	Low. Mathematical ceiling prevents prior manipulation.
T6	WORM tampering: direct PostgreSQL UPDATE of evidence record	SQLSTATE 23000 raised immediately; UPDATE rejected; SOC alert generated.	Low. All three immutability layers function correctly.

Table A2: Red team exercise results and residual risk assessments. Exercises conducted under controlled test conditions; results are indicative, not exhaustive.

E Appendix E, Supply Chain Control Summary

Control	Enforcement	Verification

Dependency license allowlist	cargo-deny, go-licenses, pip-licenses in CI	GPL/AGPL/SSPL presence blocks build
Model weight integrity	SHA-256 manifest + M-of-N HMAC-SHA256	AI Service exits(1) on mismatch at startup
M-of-N governance signing	ECDSA-P256, 2-of-3 signers required	Policy changes + model configs require 2 independent signatures
Shadow deployment gate	5% cohort, 48h parallel inference	5 validation gates; automatic rejection on any gate failure
Binary self-integrity	SHA-256 of /proc/self/exe vs baseline at startup	P0_BINARY_TAMPER event + exit(1) on mismatch
Air-gap bundle anti-replay	Monotone sequence number, Ed25519 vendor signature	Exit code 4 (DOWNGRADE_REJECTED) on replay attempt
Installer self-integrity	SHA-256 of installer binary vs MANIFEST.sha256	Installer exits before any file modification on hash mismatch
LGPL compliance (nDPI)	Dynamic linking only; LGPL text in all distribution packages	Verified by go-licenses; static linking prohibited in build configuration

Table A3: Supply chain control inventory.

F Appendix F, Key Management Reference

Key / Secret	Algorithm	Location	Permissions	Lifecycle
Root CA private key	ECDSA P-384	/opt/ransomeye/core/certs/ca_root.key	0400	Generated once at install; taken offline immediately; never used in production
Intermediate CA private key	ECDSA P-384	/opt/ransomeye/core/certs/ca_int.key	0400	Online for agent certificate enrollment; manual rotation per PRD-14
WORM Ed25519 signing key	Ed25519	/etc/ransomeye/worm_signing.key	0400	Generated once at first Core start; persisted; public key archived; manual rotation only
RANSOMEYE_MASTER_KEY	AES-256	Environment variable only (never in DB)	0400 (env file)	Generated by installer (openssl rand -hex 32); operator maintains ≥ 2 secure copies; loss = DEKs permanently inaccessible
Per-tenant DEK	AES-256-GCM	PostgreSQL tenants.dek_encrypted (wrapped under master key)	DB access	Generated per tenant at creation; wrapped under MASTER_KEY; zeroed in memory after use
Agent leaf certificate	ECDSA	/opt/ransomeye-	0400	2-year validity; certwatch

	P-256	agent/certs/agent.key		alerts at 30/14/7 days; agent-initiated auto-renewal in V0.1
Vendor Ed25519 bundle signing key	Ed25519	Compiled into ransomeye-update binary (public key only)	N/A (public)	Vendor-held private key; rotation via KEY_ROTATION bundle requiring all 3 governance signatures
RANSOMEYE_MODEL_HMAC_KEY	HMAC-SHA256	/etc/ransomeye/ai.env (environment variable)	0400	256-bit random; generated at install; used to authenticate model_config.json; verified at AI Service startup
Governance ECDSA-P256 keys (x3)	ECDSA P-256	CTO, CISO, CIO, HSM/YubiKey (V0.1); software in V0.0	Private keys: operator custody	M-of-N: 2 of 3 required for model config changes; 3 of 3 for vendor key rotation

Table A4: Key and secret management reference. Loss of RANSOMEYE_MASTER_KEY renders all encrypted evidence permanently inaccessible. Operators must maintain at least two secure offline copies.